

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiệu

TS. Đặng Văn Hiếu

Tóm tắt

Trong kỷ nguyên chuyển đổi số và bùng nổ lưu lượng mạng, các Trung tâm Điều hành An ninh (SOC) hiện đại đang đối mặt với tình trạng quá tải cảnh báo (Alert Fatigue) nghiêm trọng, khi khối lượng nhật ký thu thập từ các hệ thống giám sát vượt xa năng lực phân tích thủ công của nhân sự trực ca. Các giải pháp phòng thủ truyền thống bộc lộ rõ hạn chế: bộ lọc chữ ký tĩnh phát sinh tỷ lệ báo động giả rất cao do thiếu khả năng phân tích ngữ cảnh, trong khi các kịch bản SOAR lập trình sẵn chỉ đáp ứng được các tình huống định trước. Việc dịch chuyển sang ứng dụng Mô hình Ngôn ngữ Lớn (LLM) mở ra tiềm năng tự động hóa suy luận an ninh theo ngữ cảnh tự nhiên; tuy nhiên, hướng tiếp cận này hiện chưa thể triển khai rộng rãi do rào cản về độ trễ xử lý, chi phí tính toán lớn, các nguy cơ đối kháng nói chung (điển hình như tiêm nhiễm câu lệnh qua nhật ký - Log Prompt Injection) và rủi ro ảo giác AI. Để giải quyết các thách thức trên, luận văn đề xuất SENTINEL, một kiến trúc an ninh nhận thức hai tầng vận hành hoàn toàn cục bộ (air-gapped), thiết kế theo nguyên lý đặt phán quyết rõ đứng trước phán quyết đắt. Tầng 1 kết hợp bộ lọc thống kê Welford $\mathcal{O}(1)$ và Cổng Học máy LightGBM nhằm xử lý nhiễu nền ở tốc độ đường truyền, gỡ tải từ 90,6% đến 97,5% lưu lượng mà không tiêu tốn tài nguyên LLM, giúp giảm độ trễ trung vị toàn tuyến từ 17.174,7 ms xuống còn 0,88 ms. Tầng 2 vận hành cỗ máy tác tử LangGraph kết hợp cơ chế truy xuất lai Dual-RAG (FAISS + BM25 RRF $k = 60$) trên 433 mục tri thức MITRE ATT&CK, trong khi kênh hoãn Awaiting HITL giúp giảm 84,24% tải công việc cho chuyên viên mà vẫn đảm bảo phủ 95,0% mối đe dọa thật. Cuối cùng, cơ chế Đóng gói Nonce phân định bảo chứng cấu trúc đạt khả năng kháng triệt để trước 678 mẫu tấn công đối kháng (bao gồm tiêm nhiễm câu lệnh qua nhật ký), và chuỗi HMAC-SHA256 bảo đảm khả năng phát hiện hiệu quả các hành vi giả mạo vết kiểm toán pháp y.

Lời cảm ơn

Để hoàn thành công trình nghiên cứu này và đạt được học vị Thạc sĩ Kỹ thuật Phần mềm, tôi đã nhận được sự hỗ trợ, động viên và điều dắt quý báu từ quý Thầy Cô, đồng nghiệp cùng gia đình.

Trước hết, tôi xin bày tỏ lòng biết ơn chân thành và sự kính trọng sâu sắc nhất tới hai thầy hướng dẫn khoa học, TS. Bùi Văn Hiệu và TS. Đặng Văn Hiếu. Với tri thức học thuật uyên bác, sự định hướng chiến lược chuẩn xác và tinh thần làm việc nghiêm túc, quý Thầy đã luôn dành thời gian kiên nhẫn chỉ bảo, định hướng tư duy phản biện và truyền cảm hứng nghiên cứu cho tôi trong suốt chặng đường thực hiện luận văn. Những góp ý chuyên môn sắc bén của quý Thầy không chỉ giúp tôi hoàn thiện công trình này mà còn là hành trang tri thức vô giá cho sự nghiệp nghiên cứu an toàn thông tin và trí tuệ nhân tạo của tôi trong tương lai.

Tôi xin trân trọng gửi lời tri ân tới Ban Giám hiệu, Ban Lãnh đạo Viện Quản trị & Công nghệ FSB cùng toàn thể quý Thầy Cô Trường Đại học FPT đã truyền dạy nền tảng tri thức lý thuyết và thực tiễn vững chắc trong một môi trường nghiên cứu chuyên nghiệp. Tôi cũng xin chân thành cảm ơn Ban Lãnh đạo cùng toàn thể đồng nghiệp tại Cục C12, Trung tâm Dữ liệu Quốc gia. Sự tin tưởng, điều kiện thuận lợi về thời gian cùng những kinh nghiệm thực chiến phong phú từ đơn vị đã đem lại góc nhìn thực tiễn sâu sắc, góp phần quan trọng vào quá trình thiết kế, thực nghiệm và hoàn thiện hệ thống SENTINEL.

Cuối cùng, tôi xin dành trọn lòng tri ân sâu sắc nhất tới gia đình thân yêu, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn và nguồn động viên không ngừng nghỉ của gia đình trong suốt quá trình tôi miệt mài thực hiện nghiên cứu chính là điểm tựa vững chắc nhất giúp tôi hoàn thành luận văn này. Mặc dù đã nỗ lực hết mình, luận văn khó tránh khỏi những thiếu sót nhất định; tôi rất mong nhận được sự chỉ dẫn và đóng góp quý báu từ quý Thầy Cô trong Hội đồng cùng quý độc giả.

Mục lục

Tóm tắt	i
Lời cảm ơn	ii
Danh sách hình vẽ	iv
Danh sách bảng	iv
Danh mục các từ viết tắt	vi
1 Giới thiệu	1
1.1 Bối cảnh và Động lực Nghiên cứu	1
1.2 Mục tiêu, Câu hỏi Nghiên cứu, Phạm vi và Đóng góp	2
1.3 Cấu trúc của Luận văn	3
2 Cơ sở Lý thuyết và Tổng quan Nghiên cứu	4
2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức	4
2.2 Lý thuyết Luật tắt định, Thông kê Trục tuyến và Học máy Tầng 1	5
2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2	5
2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký	6
2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu	7
3 Thiết kế Hệ thống và Triển khai Kỹ thuật	9
3.1 Phương pháp Nghiên cứu	9
3.2 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC	10
3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy	11
3.4 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đe dọa	13
3.5 Cơ chế Truy xuất Tri thức Lai Dual-RAG	14
3.6 Kiến trúc An ninh AI và Niêm phong Kiểm toán Mật mã	15
4 Thực nghiệm và Đánh giá	17
4.1 Xả tải và Kinh tế học Tầng lọc	17
4.2 RQ2: Rào chắn An ninh AI và Toàn vẹn Pháp y	21
4.3 RQ3: Suy luận Có trạng thái và Quy kết Kỹ thuật	24
5 Kết luận	29
Tài liệu tham khảo	1

Danh sách hình vẽ

Hình 1.	Sơ đồ kiến trúc tổng thể SENTINEL. (Nguồn: Tác giả)	11
Hình 2.	Sơ đồ chi tiết Tầng 1. (Nguồn: Tác giả)	12
Hình 3.	Đồ thị trạng thái tác tử Tầng 2. (Nguồn: Tác giả)	14
Hình 4.	Sơ đồ truy xuất Dual-RAG và rào chắn neo bằng chứng đầu ra. (Nguồn: Tác giả)	15
Hình 5.	Cơ chế đóng gói Nonce đầu vào và chuỗi niêm phong HMAC đầu ra. (Nguồn: Tác giả)	16
Hình 6.	Cơ cấu xả tải trên hai luồng; tầng gánh chính đảo vai theo tỉ lệ tấn công nền. Sinh từ <code>offload_vs_baserate_{stream,demo}.json</code> . (Nguồn: Tác giả)	18
Hình 7.	Phân phối tích lũy độ trễ trên cùng 500 sự kiện. Lợi thế tập trung ở thân phân phối; ở phần đuôi thì hệ hai tầng chậm hơn. Sinh từ <code>latency_benchmark.json</code> . (Nguồn: Tác giả)	20
Hình 8.	Lớp lọc tĩnh: tỉ lệ chặn theo xuất xứ đặt cạnh tỉ lệ báo nhảm trên log lạnh. Sinh từ <code>robustness_results.json</code> và <code>adversarial_negative_results.json</code> . (Nguồn: Tác giả) . . .	23
Hình 9.	Quy kết theo từng kỹ thuật đặt cạnh trần truy xuất. Chỗ nào cột nhật cao mà hai cột đậm bằng không thì lỗi ở bộ ánh xạ; chỗ nào cột nhật bằng không thì lỗi ở kho tri thức. Sinh từ ba tệp kết quả RQ3. (Nguồn: Tác giả)	25
Hình 10.	Phân loại cảnh báo ở Tầng 2. Kênh khẳng định gần như toàn báo giả; kênh hoãn mới là nơi đe dọa thật dồn về. Sinh từ <code>tier2_decision_results.json</code> . (Nguồn: Tác giả)	26
Hình 11.	Trái: độ chính xác hành động theo cấu hình kèm khoảng tin cậy 95%; A và F chung mẫu số, B–E thì không. Phải: bốn trục trọng tài chấm, với độ chính xác ngữ cảnh là trục yếu. Sinh từ <code>ablation_action_scores.json</code> và <code>reasoning_eval_results.json</code> . (Nguồn: Tác giả)	28

Danh sách bảng

Bảng 1.	Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành	8
Bảng 2.	Tỉ lệ Xả tải theo Từng Tầng trên Hai Luồng có Base-rate Khác nhau	18
Bảng 3.	Thông lượng các cấu hình đối chứng trên cùng mẫu con 150 sự kiện phân tầng	20
Bảng 4.	Các lớp rào chắn, mẫu số phép đo và kết quả	22
Bảng 5.	Quy kết theo từng kỹ thuật trên lát 500 mẫu tầng payload, kèm trần truy xuất của cùng bộ truy vấn.	25
Bảng 6.	Bóc tách thành phần chấm theo hành động cuối, đã loại 50 mẫu tác giả tự soạn. Cấu hình A và F chấm trên toàn bộ 1.700 mẫu còn lại; B–E chấm trên một lát 300 mẫu riêng nên không so trực tiếp với A và F được. Sinh từ <code>ablation_action_scores.json</code>	27

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
AUC-ROC	Area Under the Receiver Operating Characteristic Curve (Diện tích dưới đường cong đặc tính hoạt động của bộ thu)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
DSRM	Design Science Research Methodology (Phương pháp luận nghiên cứu khoa học thiết kế)
ECDF	Empirical Cumulative Distribution Function (Hàm phân phối tích lũy thực nghiệm)
FAISS	Facebook AI Similarity Search (Cỗ máy tìm kiếm tương đồng FAISS)
FNR	False Negative Rate (Tỷ lệ bỏ sót báo động)
FPR	False Positive Rate (Tỷ lệ báo động giả)
FSM	Finite State Machine (Máy trạng thái hữu hạn)
GGUF	GPT-Generated Unified Format (Định dạng hợp nhất GGUF)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông điệp dựa trên hàm băm)
IDS / IPS	Intrusion Detection / Prevention System (Hệ thống phát hiện và ngăn ngừa xâm nhập)
KV	Key-Value (Khóa - Giá trị trong cơ chế bộ nhớ đệm KV-Cache)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge (Khung tri thức chiến thuật và kỹ thuật tấn công MITRE)
NIST	National Institute of Standards and Technology (Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOAR	Security Orchestration, Automation, and Response (Điều phối, tự động hóa và phản hồi an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)
TPR	True Positive Rate (Tỷ lệ phát hiện đúng)
WAF	Web Application Firewall (Tường lửa ứng dụng Web)

Chương 1

Giới thiệu

Chương này xác lập bối cảnh nghiên cứu và bài toán trung tâm của SENTINEL, một kiến trúc an ninh nhận thức hai tầng tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh (SOC), cùng mục tiêu, câu hỏi nghiên cứu, đối tượng, phạm vi và đóng góp khoa học của luận văn.

1.1 Bối cảnh và Động lực Nghiên cứu

Trong kỷ nguyên chuyển đổi số và bùng nổ lưu lượng mạng, các Trung tâm Điều hành An ninh (SOC) hiện đại đang đối mặt với tình trạng quá tải cảnh báo (Alert Fatigue) nghiêm trọng, khi khối lượng nhật ký thu thập mỗi ngày lên tới hàng triệu sự kiện vượt xa năng lực phân tích thủ công [1]. Nhằm tránh bỏ lọt sự cố, các hệ thống giám sát được cấu hình nghiêng về phía tăng độ nhạy, dẫn đến việc phần lớn cảnh báo gửi về hàng đợi chỉ ghi nhận hoạt động vận hành bình thường và không thực sự yêu cầu sự can thiệp trực tiếp của chuyên viên [2, 3]. Do đó, nút thắt cổ chai của SOC hiện đại không nằm ở năng lực thu thập dữ liệu, mà nằm ở khả năng phân bổ nguồn lực chú ý khan hiếm của nhân sự trực ca.

Ba lớp phòng thủ truyền thống gồm tường lửa kết hợp hệ thống phát hiện xâm nhập (IDS/IPS) dựa trên chữ ký tĩnh, nền tảng SIEM gom tương quan dữ liệu bằng luật viết tay, và kịch bản SOAR lập trình sẵn bộc lộ rõ hạn chế: thiếu khả năng suy luận ngữ cảnh động và chỉ ứng phó được các tình huống định trước [4]. Những sự kiện vượt qua ba lớp phòng thủ này đều đẩy về hàng đợi thủ công, buộc chuyên viên phải thực hiện chuỗi thao tác tốn thời gian: trích xuất nhật ký thô, tái dựng hành vi địa chỉ nguồn, đối chiếu tài sản nội bộ và quy kết kỹ thuật tấn công trước khi ra quyết định xử lý. Quy trình tuần tự này vừa

tạo ra rào cản thời gian gây tổn động hàng đợi, vừa chịu rào cản ngữ cảnh do bằng chứng quyết định nằm rải rác trên nhiều bản ghi phi cấu trúc.

Dịch chuyển sang ứng dụng Mô hình Ngôn ngữ Lớn (LLM) mở ra tiềm năng tự động hóa suy luận an ninh theo ngữ cảnh tự nhiên; tuy nhiên, hướng tiếp cận này đối mặt với ba rào cản lớn: (1) độ trễ suy luận hàng giây của LLM mâu thuẫn với tốc độ dữ liệu đường truyền [5]; (2) tầng suy luận AI trở thành mục tiêu tấn công đối kháng qua kỹ thuật tiêm nhiễm câu lệnh (Log Prompt Injection) [6], đòi hỏi vết kiểm toán phải được niêm phong bảo đảm tính toàn vẹn; và (3) dữ liệu an ninh nội bộ bắt buộc vận hành cục bộ (air-gapped) trên phần cứng hữu hạn do yêu cầu bảo mật nghiêm ngặt [7]. Khoảng cách 4 đến 5 bậc độ lớn về chi phí tính toán giữa luật thống kê truyền thống ($\ll 1$ ms) và LLM (hàng giây) đặt ra yêu cầu phải thiết kế kiến trúc SENTINEL theo nguyên lý *đặt phán quyết rẽ đứng trước phán quyết đất*: xả tải nhiều nền ở tầng lọc tốc độ cao và chỉ gọi tầng suy luận LLM cho các sự kiện thực sự cần thiết.

1.2 Mục tiêu, Câu hỏi Nghiên cứu, Phạm vi và Đóng góp

Để giải quyết bài toán trung tâm, mục tiêu tổng quát của luận văn được chia tách thành ba trục nghiên cứu độc lập nhưng hỗ trợ chặt chẽ lẫn nhau, đặt tương ứng với ba câu hỏi nghiên cứu (RQ) và các đóng góp khoa học chính. Toàn bộ thiết kế và kết quả thực nghiệm định lượng được minh chứng tại Chương 4.

Trục thứ nhất tập trung vào phân tầng lưu lượng: thiết kế đường ống lọc hai chặng phi trạng thái ở tốc độ đường truyền nhằm xả tải dữ liệu tại tầng tính toán rẻ. RQ1 được xác lập như sau: *Làm thế nào để thiết kế một kiến trúc phân tầng có khả năng xả tải tự động luồng dữ liệu an ninh ở tốc độ đường truyền nhằm giải quyết nút thắt cổ chai về độ trễ và tài nguyên của Mô hình Ngôn ngữ Lớn?* Đóng góp tương ứng là định lượng nguyên lý đặt phán quyết rẽ đứng trước phán quyết đất và chứng minh thực nghiệm mối quan hệ giữa tỷ lệ xả tải với tỷ lệ tấn công nền.

Trục thứ hai tập trung vào an toàn suy luận và kiểm toán: bảo vệ mô hình ngôn ngữ bằng

rào chắn cấu trúc và niêm phong vết pháp y. RQ2 được xác lập như sau: *Phương pháp luận và cơ chế bảo mật nào chống lại rủi ro đối kháng qua nhật ký nhằm bảo vệ luồng suy luận AI, đồng thời bảo đảm tính toàn vẹn của chứng cứ pháp y?* Đóng góp tương ứng là cơ chế Đóng gói Dữ liệu Phân định với Nonce mật mã (Delimited Nonce Encapsulation), bảo chứng cấu trúc bất định độc lập với bộ phân loại xác suất [8].

Trục thứ ba tập trung vào suy luận nhận thức và phân loại sự cố: xây dựng tác tử suy luận tích hợp tri thức an ninh chuyên ngành. RQ3 được xác lập như sau: *Làm thế nào để tích hợp năng lực suy luận có trạng thái và tra cứu tri thức chuyên ngành vào Tác tử AI nhằm tự động hóa phân tích, quy kết kỹ thuật tấn công và sinh báo cáo minh bạch?* Đóng góp tương ứng là tác tử LangGraph có trạng thái vận hành trên kho tri thức MITRE ATT&CK chuẩn STIX, kết hợp rào chắn neo-RAG hạn chế ảo giác mô hình.

Phạm vi và phương pháp luận của luận văn được xác lập cụ thể: Khách thể nghiên cứu là quy trình tự động hóa phân tích, xả tải cảnh báo và bảo vệ mô hình AI trong SOC. Đối tượng nghiên cứu bao gồm thuật toán phân tầng tốc độ cao (bộ luật chữ ký tầng ứng dụng Rule-based, thống kê Welford $\mathcal{O}(1)$ kết hợp Cổng Học máy LightGBM), cơ chế phòng thủ đối kháng bất định (Nonce Encapsulation và HMAC-SHA256), cùng tác tử suy luận an ninh có trạng thái (LangGraph FSM) tích hợp truy xuất tri thức lai (Dual-RAG FAISS + BM25 RRF). Về phạm vi thực nghiệm, SENTINEL được đánh giá trên hai tập benchmark CSE-CIC-IDS2018 [10] và CSIC 2010 [11], kết hợp 823 mẫu đối kháng (AdvBench [13], deepset [14], jackhhao [15]) trên máy trạm cách ly mạng (air-gapped).

1.3 Cấu trúc của Luận văn

Chương 2 hệ thống hóa cơ sở lý thuyết và tổng quan các công trình liên quan nhằm xác định khoảng trống nghiên cứu. Chương 3 trình bày phương pháp luận nghiên cứu và thiết kế kỹ thuật chi tiết của hệ thống SENTINEL. Chương 4 trình bày kết quả đánh giá thực nghiệm định lượng, được tổ chức tương ứng theo đúng ba câu hỏi nghiên cứu ở trên. Chương 5 tổng kết các đóng góp, thảo luận về những hạn chế và đề xuất hướng phát triển trong tương lai.

Chương 2

Cơ sở Lý thuyết và Tổng quan Nghiên cứu

Chương này trình bày các nguyên lý lý thuyết nền tảng của luận văn, bao gồm: thực trạng vận hành SOC và nút thắt nhận thức, cơ sở luật tất định, thống kê trực tuyến và học máy Tầng 1, kiến trúc tác tử và mô hình ngôn ngữ lớn Tầng 2, nguy cơ đối kháng và kiểm toán mật mã, cùng tổng quan các nghiên cứu liên quan nhằm xác định khoảng trống nghiên cứu mà SENTINEL giải quyết.

2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức

Mục này đi sâu phân tích các nguyên nhân kiến trúc cốt lõi gây nên tình trạng quá tải cảnh báo đã được phác thảo tại Chương 1. Trong mô hình SOC tiêu chuẩn, công tác giám sát dựa vào việc hợp nhất nhật ký thô từ các cảm biến như Tường lửa thế hệ mới (NGFW), Hệ thống phát hiện xâm nhập (IDS/IPS) và giải pháp Phản hồi Điểm cuối (EDR) về nền tảng SIEM tập trung [1], với khối lượng vượt xa năng lực phân tích thủ công của con người [16]. Nút thắt khởi nguồn từ cơ chế vận hành của các cảm biến đầu vào: chúng thực hiện phán quyết chủ yếu dựa trên chữ ký tĩnh hoặc các luật tương quan tất định. Do áp lực tránh bỏ lọt sự cố luôn đi kèm thiệt hại lớn, người vận hành bị buộc phải hạ ngưỡng phát hiện. Tuy nhiên, việc hạ ngưỡng trong các hệ thống dựa trên chữ ký chỉ làm gia tăng khối lượng báo động giả gửi về hàng đợi mà không thể nâng cao năng lực phân tích ngữ cảnh [2, 3].

Ở lớp trên, các nền tảng Điều phối và Tự động hóa An ninh (SOAR) được triển khai nhằm giảm tải thao tác bằng cách thực thi các kịch bản ứng phó (playbooks) lập trình sẵn [4]. Dù vậy, ranh giới của SOAR bị siết chặt bởi tính cố định của kịch bản: một playbook chỉ kích hoạt thành công khi cảnh báo khớp chính xác với tình huống đã được lường trước. Đối với

các chuỗi tấn công phức tạp, hành vi bất thường mới hoặc bằng chứng phi cấu trúc nằm rải rác, cả ba lớp SIEM, IDS/IPS và SOAR đều không thể hình thành phán quyết ngữ cảnh. Toàn bộ các ca nghi ngờ này buộc phải chuyển về hàng đợi thủ công, biến chuyên viên trực ca thành nút thắt cổ chai nhận thức duy nhất của toàn bộ hệ thống.

2.2 Lý thuyết Luật tắt định, Thống kê Trực tuyến và Học máy Tầng 1

Yêu cầu vận hành ở tốc độ đường truyền đặt ra ràng buộc chặt chẽ về mặt thuật toán cho Tầng 1: các cơ chế xử lý phải đạt độ phức tạp thời gian và bộ nhớ hằng số $\mathcal{O}(1)$. Đầu tiên, lớp phòng thủ dựa trên luật (Rule-based) sử dụng các tập hợp đối sánh tĩnh và tra cứu cổng dịch vụ để loại bỏ tức thời các hành vi bất thường thô mà không tiêu tốn tài nguyên tính toán. Tiếp theo, cơ chế theo dõi đường nền áp dụng công thức truy hồi tăng dần Welford [17] để cập nhật liên tục giá trị trung bình μ_k và tổng bình phương độ lệch S_k theo từng quan sát, tính toán độ lệch chuẩn $\sigma_k = \sqrt{S_k/(k-1)}$ và điểm Z-score động mà không cần lưu trữ nhật ký quá khứ:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

Cuối cùng, các mô hình Học máy dựa trên Cây quyết định tăng cường độ dốc (GBDT), tiêu biểu là thuật toán LightGBM [18], cung cấp năng lực phân loại nhanh các mẫu dữ liệu đa chiều. Việc kết hợp lọc luật tắt định, chuẩn hóa thống kê Z-score và phân loại học máy tạo thành tuyến phòng thủ đa tầng tốc độ cao, vừa đảm bảo xả tải lưu lượng lớn vừa duy trì tính ổn định trước các biến thể dữ liệu đối kháng.

2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2

Vận hành mô hình suy luận hoàn toàn cục bộ là điều kiện bắt buộc để bảo đảm chủ quyền dữ liệu an ninh nội bộ, nhưng đồng thời đặt ra giới hạn nghiêm ngặt về tài nguyên bộ nhớ GPU. Kỹ thuật lượng tử hóa giúp nén biểu diễn trọng số sang lưới số nguyên thô hơn, đánh

đổi một lượng nhỏ độ trung thực số học để giảm đáng kể dung lượng bộ nhớ [19]. Ở định dạng GGUF Q4_K_M, mô hình chuyên biệt an ninh Foundation-Sec-8B-Instruct [20, 21] chỉ chiếm khoảng 7–8 GB VRAM, chứa đủ không gian cho bộ đệm ngữ cảnh và chỉ mục truy xuất trên card đồ họa GPU cục bộ.

Tầng suy luận điều phối quy trình phân tích thông qua đồ thị trạng thái LangGraph [22]. Nhằm khắc phục hạn chế ảo giác và neo phán quyết vào chứng cứ thực tế [23], hệ thống kết hợp kỹ thuật truy xuất thông tin lai giữa tìm kiếm véc-tơ dày (FAISS) [24] và đối sánh từ khóa thưa (BM25) [25]. Kết quả truy xuất từ hai phương pháp được hợp nhất theo thứ hạng bằng thuật toán Reciprocal Rank Fusion (RRF) [26]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

giúp đối chiếu minh bạch dữ liệu nhật ký với các mã kỹ thuật MITRE ATT&CK [35] và hướng dẫn ứng phó sự cố NIST SP 800-61r2 [36].

2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký

Tích hợp Mô hình Ngôn ngữ Lớn vào quy trình phân tích an ninh làm phát sinh rủi ro bị tấn công tiêm nhiễm câu lệnh qua nhật ký (Log Prompt Injection) [6, 8]. Do nội dung nhật ký do chính bên tấn công khởi tạo, các giải pháp phòng thủ dựa trên phân loại nội dung hoặc lọc từ khóa xác suất thường dễ bị qua mặt trước các biến thể câu lệnh đối kháng mới [27]. Căn cứ lý thuyết đó đặt ra yêu cầu phải bảo vệ tầng suy luận bằng cơ chế cách ly cấu trúc tất định (Delimited Nonce Encapsulation), phân tách ranh giới tuyệt đối giữa chỉ thị điều khiển và dữ liệu thô bị nghi nhiễm.

Đối với tính toàn vẹn của hồ sơ phân tích, các vết chứng cứ pháp y được niêm phong theo chuỗi bằng thuật toán mã hóa HMAC-SHA256 [28] sử dụng khóa bí mật cục bộ. Về mặt ranh giới lý thuyết, cơ chế mã hóa đối xứng HMAC đảm bảo khả năng phát hiện mọi hành vi chỉnh sửa hoặc giả mạo nhật ký, nhưng không thay thế cho thuộc tính chống chối bỏ (non-repudiation) vốn đòi hỏi hạ tầng chữ ký số bất đối xứng.

2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu

Nghiên cứu ứng dụng trí tuệ nhân tạo trong vận hành an ninh mạng đã tiến triển qua ba nhóm giải pháp kiến trúc chính, theo khảo sát hệ thống của Zhang và cộng sự [29].

Nhóm thứ nhất, phòng thủ doanh nghiệp truyền thống, gồm các nền tảng SIEM như IBM QRadar và giải pháp SOAR như Palo Alto Cortex XSOAR [1, 4], tương quan sự kiện bằng tập luật tĩnh và chạy kịch bản định sẵn. Bối trợ cho nhóm này là các kỹ thuật phân tích nhật ký trực tuyến kinh điển như Drain [34], giúp rút gọn cú pháp nhưng chưa thể phân tích ngữ cảnh hành vi. Qua phỏng vấn người vận hành SOC, AlAhmadi và cộng sự [3] ghi nhận chất lượng cảnh báo thấp là nguyên nhân hàng đầu gây nên tình trạng quá tải. Ưu thế duy nhất của nhóm này là độ trễ rất thấp, đặc tính mà Tầng 1 của SENTINEL kế thừa và phát triển.

Nhóm thứ hai, tác tử phân loại có tăng cường truy xuất, tiêu biểu là CyberRAG [30], điều phối các bộ phân loại tĩnh chỉnh theo từng họ tấn công phía sau một tác tử LLM và công bố độ chính xác trên 94% trên các phép thử tấn công web. Công trình này giải quyết chất lượng phân tích cho những sự kiện đã chọn, nhưng thiếu tầng lọc tốc độ đường truyền ở đầu nguồn để quản lý lưu lượng lớn.

Nhóm thứ ba, đa tác tử và chú trọng quản trị, gồm AutoBnB-RAG [31], LanG [32] và Policy-Guided Threat Hunting [33]. AutoBnB-RAG đánh giá phản ứng sự cố trong môi trường mô phỏng trò chơi bàn *Backdoors & Breaches*. LanG dựng trên LangGraph tích hợp phòng thủ tiềm ẩn bằng bộ phân loại xác suất (Llama Prompt Guard 2 đạt F1 98,1%). Policy-Guided Threat Hunting sử dụng bộ tự mã hoá tái dựng và học tăng cường sâu hai lớp để tiền phân loại trước khi đưa vào LLM.

Khoảng trống nghiên cứu được xác định rõ ràng: phân tầng chi phí đã xuất hiện ở Policy-Guided Threat Hunting, phòng thủ tiềm ẩn đã có ở LanG, và vận hành cục bộ đã được triển khai ở một số công trình. Tuy nhiên, chưa có kiến trúc đơn lẻ nào hợp nhất thành công: (1) giải quyết phần lớn lưu lượng ở tầng thống kê/học máy với độ trễ dưới 1 ms và công bố tỷ lệ gỡ tải theo tỷ lệ tấn công; (2) suy luận có trạng thái chạy trên GPU cục bộ dưới quy tắc neo truy xuất nghiêm ngặt; và (3) bảo chứng phòng thủ tiềm ẩn dựa trên cấu trúc

kết hợp với niêm phong pháp y HMAC-SHA256. Bảng 1 đối chiếu chi tiết SENTINEL với các nhóm giải pháp đại diện.

Bảng 1. Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành

Tiêu chí Đánh giá	SIEM / SOAR (QRadar, XSOAR)	Hệ tác tử LLM (CyberRAG, LanG, Policy-Guided)	Kiến trúc SENTINEL (Luận văn)
Kỹ thuật Cốt lõi	Tập luật tương quan tính, kịch bản Python/JS cứng	RAG tác tử, điều phối đa tác tử, phân loại sơ bộ bằng DRL	Bộ luật chữ ký Rule-based + Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Mục tiêu Vận hành	Gom nhật ký tập trung và phản hồi theo kịch bản	Tự động hóa điều tra sự cố bằng suy luận ngôn ngữ	Giải quyết lưu lượng tại tầng rẻ, dành tầng đắt cho ca cần suy luận
Độ trễ & Phân tầng	Một tầng rẻ, không suy luận ngữ cảnh	Có ở một số công trình (DRL sơ bộ); chưa mô hình hóa tỷ lệ gỡ tải theo mức độ tấn công	Hai tầng: $\leq 0,88$ ms ở T1; gỡ tải 90% – 97% lưu lượng trước T2
Chủ quyền Dữ liệu	Cục bộ nội bộ	Triển khai cục bộ nhưng không ấn định giới hạn phần cứng nghiêm ngặt	Air-gapped 100% trên GPU cục bộ
Chống Prompt Inj.	Không áp dụng	Bộ phân loại xác suất (LanG: regex + Prompt Guard 2, F1 98,1%)	Bảo chứng cấu trúc (Nonce), độc lập với câu chữ payload
Kiểm toán Pháp y	Nhật ký văn bản tiêu chuẩn (dễ bị chỉnh sửa)	Có công bố nhật ký kiểm toán (LanG: mcp_audit.db); không niêm phong mật mã	Chuỗi HMAC-SHA256 phát hiện giả mạo vết chứng cứ

Chương 3

Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày phương pháp nghiên cứu, sau đó đi sâu chi tiết thiết kế và cài đặt thực nghiệm hệ thống SENTINEL, bao gồm: luồng xử lý hai tầng, bộ lọc tốc độ đường truyền và Cổng Học máy Tầng 1, tác tử nhận thức LangGraph và Bộ nhớ Đe dọa Tầng 2, cơ chế truy xuất tri thức lai Dual-RAG, cùng các giải pháp an ninh đối kháng AI kèm niêm phong kiểm toán mật mã.

3.1 Phương pháp Nghiên cứu

Luận văn tiếp cận theo phương pháp Nghiên cứu Khoa học Thiết kế (Design Science Research Methodology - DSRM) [41]. Đóng góp trung tâm của nghiên cứu là một hệ thống thực nghiệm (artefact), được đánh giá định lượng thông qua các thước đo thực nghiệm khách quan thay vì các lập luận cảm quan thuần túy. Hệ thống được cấu thành bởi ba trụ cột kỹ thuật chính:

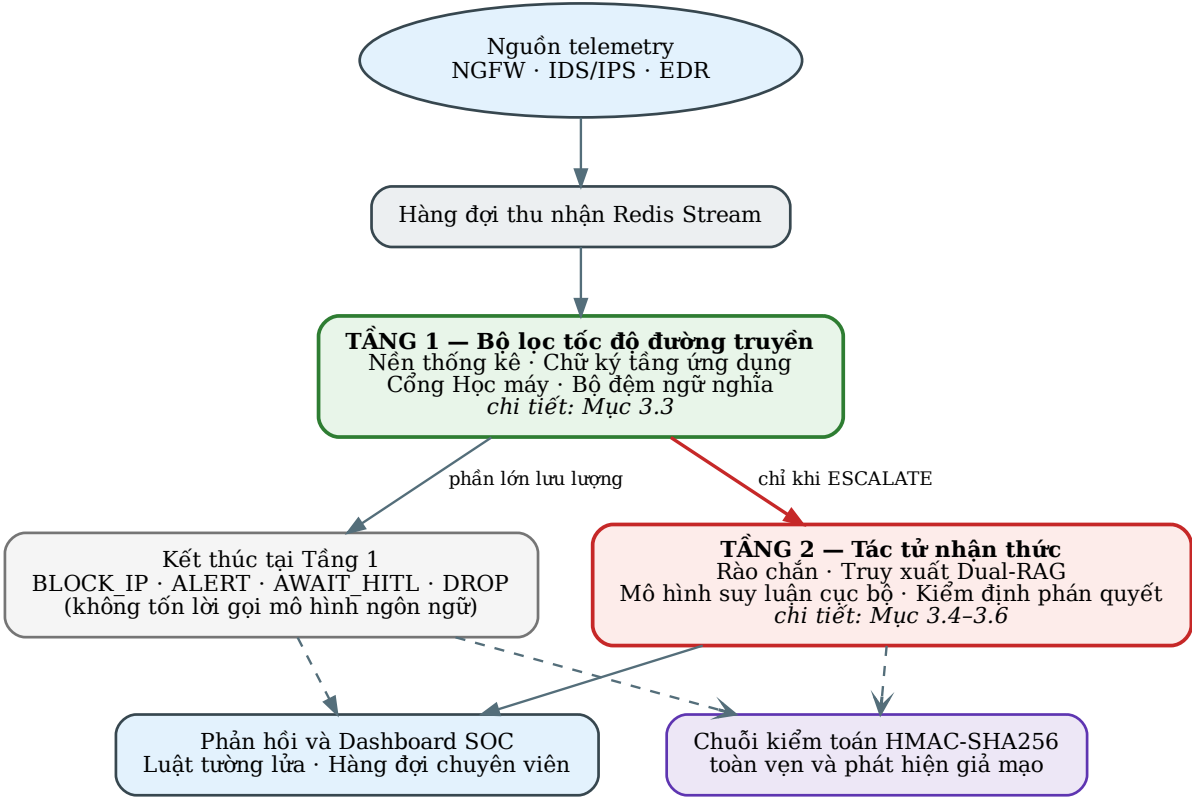
1. *Trụ cột luật tĩnh, thống kê và học máy*: Cung cấp năng lực lọc lưu lượng ở tốc độ đường truyền nhờ bộ luật chữ ký tầng ứng dụng (Rule-based), thuật toán thống kê trực tuyến Welford $\mathcal{O}(1)$ [17] kết hợp với Cổng Học máy LightGBM [18].
2. *Trụ cột logic tác tử*: Cung cấp năng lực suy luận ngữ cảnh sâu nhờ đồ thị trạng thái LangGraph [22] điều phối mô hình ngôn ngữ Foundation-Sec-8B-Instruct [20] vận hành cục bộ trên nền truy xuất lai FAISS/BM25/RRF [24–26].
3. *Trụ cột an ninh đối kháng*: Thiết lập ranh giới phòng thủ chắc chắn chống lại rủi ro tiêm nhiễm câu lệnh qua nhật ký [6, 8] và niêm phong vết chứng cứ bằng chuỗi mã hóa HMAC-SHA256 [28].

Hiệu lực vận hành của kiến trúc SENTINEL được đánh giá định lượng trên 5 chiều đo lường cốt lõi: chất lượng phân loại sự cố, hiệu năng xử lý và thời gian phản hồi, khả năng kháng tấn công đối kháng, độ mạch lạc của lời giải thích an ninh (được chấm điểm độc lập bởi mô hình trọng tài), cùng tính toàn vẹn của hồ sơ kiểm toán pháp y. Toàn bộ các kết quả thực nghiệm, phân tích đối chứng và kiểm chứng giới hạn hệ thống sẽ được trình bày chi tiết tại Chương 4.

3.2 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC

SENTINEL vận hành theo kiến trúc nhận thức hai tầng với nguyên lý cốt lõi là phân tách khối lượng công việc theo chi phí tính toán. Nhật ký thô từ các nguồn cảm biến vành ngoài được đẩy vào hàng đợi Redis Stream rồi chuyển tới Tầng 1. Tầng 1 đóng vai trò là chặng xử lý thống kê và học máy phi trạng thái, giải quyết phần lớn lưu lượng ở tốc độ đường truyền. Trong tập hành động của Tầng 1, chỉ duy nhất phán quyết ESCALATE được chuyển giao lên Tầng 2; các phán quyết còn lại (BLOCK_IP, ALERT, AWAIT_HITL, DROP) đều kết thúc xử lý ngay tại Tầng 1. Đây là căn cứ xác lập khái niệm tỷ lệ gỡ tải (offload rate) tại Chương 4: một sự kiện được tính là gỡ tải thành công khi không kích hoạt bất kỳ lời gọi suy luận mô hình ngôn ngữ nào.

Tại Tầng 2, tác tử LangGraph [22] tiến hành suy luận sâu theo ngữ cảnh trên mô hình chuyên biệt an ninh Foundation-Sec-8B-Instruct [20] (lượng tử hóa GGUF Q4_K_M), kết hợp trạng thái lịch sử từ Bộ nhớ Đe dọa và tri thức truy xuất từ Dual-RAG. Đầu ra được kiểm soát bởi rào chắn tắt định giới hạn trong 3 trạng thái cho phép (BLOCK_IP, LOG, AWAIT_HITL), với mọi bản ghi từ cả hai tầng đều được niêm phong mật mã bằng chuỗi HMAC-SHA256 [28]. Nhờ đó, SENTINEL đóng vai trò là tầng trung gian nhận thức (cognitive middleware) giữa SIEM và các giải pháp thực thi phòng thủ (NGFW/SOAR), giúp hấp thụ nhiều lưu lượng ở Tầng 1 và giải thích minh bạch cho các sự kiện leo thang ở Tầng 2, bảo đảm chủ quyền dữ liệu khi vận hành cách ly mạng (air-gapped) trên GPU cục bộ [7]. Sơ đồ luồng xử lý và mối liên kết giữa các thành phần được thể hiện chi tiết tại Hình 1.

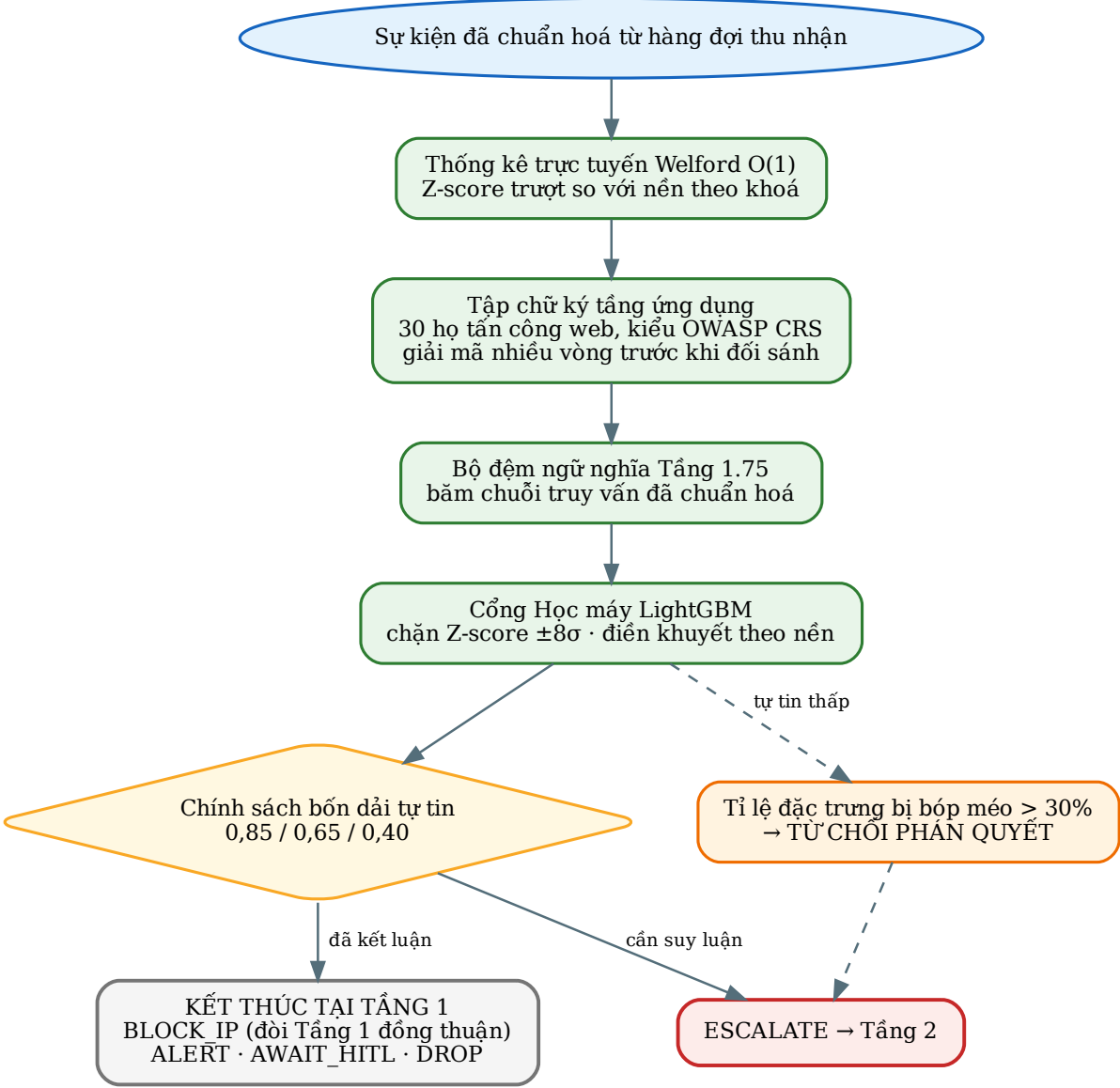


Hình 1. Sơ đồ kiến trúc tổng thể SENTINEL. (Nguồn: Tác giả)

3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy

Tầng 1 vận hành như vành ngoài phi trạng thái tốc độ đường truyền, hợp nhất bộ chữ ký tầng ứng dụng và bộ lọc thống kê đường nền Welford $\mathcal{O}(1)$ [17] (Công thức 2.1). Tập chữ ký gồm 30 họ tấn công chuẩn hóa OWASP CRS 3.3 [9] (23 họ bao phủ OWASP Top 10:2021; 7 họ nhận diện bất thường mạng và điểm cuối như ransomware, đào tiền mã hóa). Song song đó, bộ lọc Welford tính toán Z-score tức thời $Z = (x - \mu) / \sigma$ trên các đặc trưng lưu lượng (tần suất gói tin, dung lượng luồng, thời lượng) và liên tục cập nhật tham số μ, σ để tự động loại bỏ lưu lượng lành tính. Sơ đồ luồng xử lý chi tiết tại Tầng 1 được thể hiện tại Hình 2.

Đối với lưu lượng lặp lại khối lượng lớn (DDoS, dò quét mật khẩu), Bộ đệm Ngữ nghĩa Tầng 1.75 băm chuỗi truy vấn trong RAM để tái sử dụng phán quyết trong < 1 ms mà



Hình 2. Sơ đồ chi tiết Tầng 1. (Nguồn: Tác giả)

không cần tính toán lại.

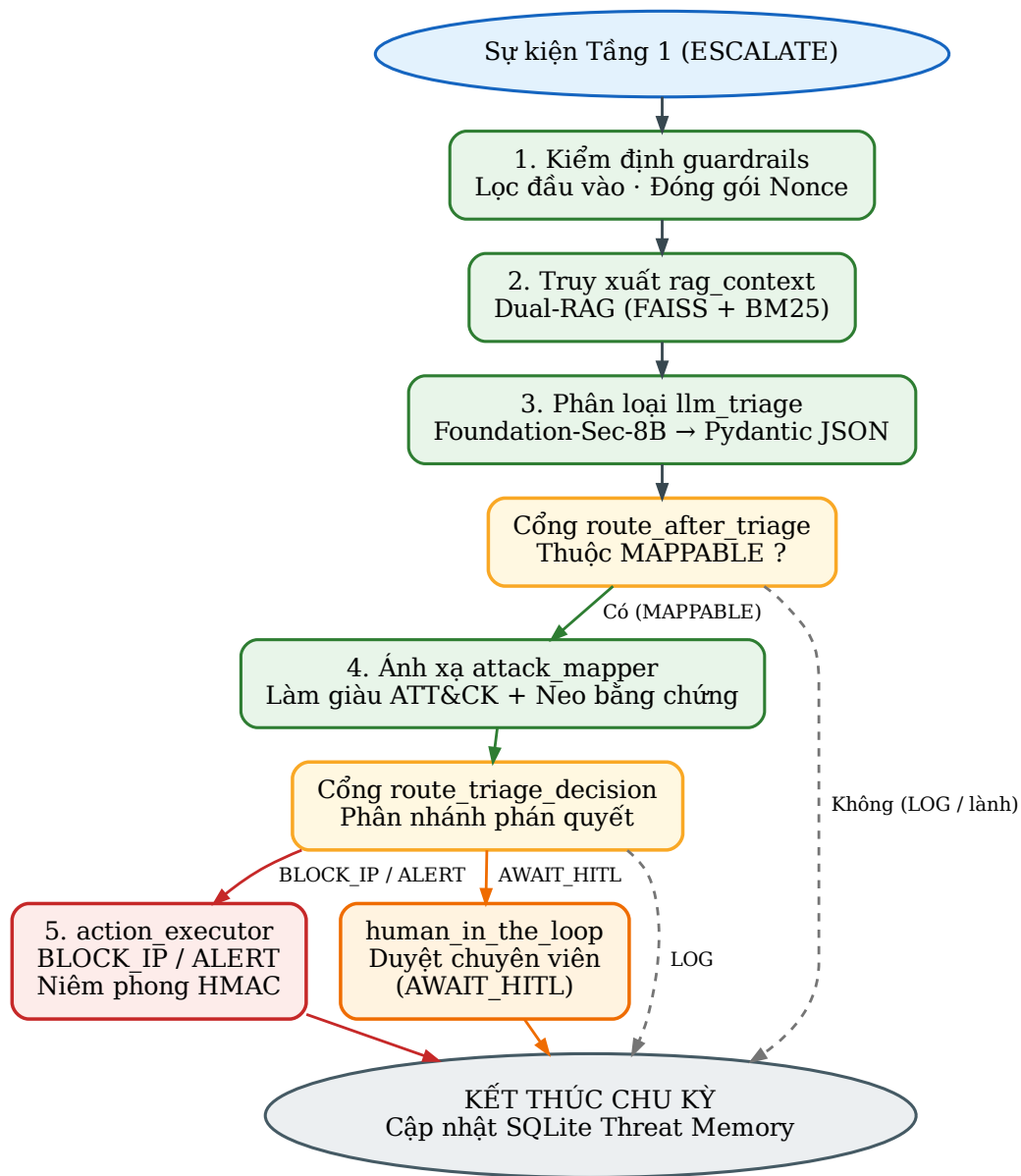
Tiếp nối là Cổng Học máy LightGBM [18], phân tích tương tác đặc trưng phi tuyến trên 949.535 mẫu NetFlow trích từ bộ dữ liệu CSE-CIC-IDS2018 [10] (664.674 mẫu huấn luyện, 189.907 mẫu kiểm thử). Để chống né tránh đối kháng (anti-evasion), Cổng Học máy kẹp Z-score trong $[-8, 8]\sigma$, bù giá trị khuyết bằng trung bình đường nền, và tự động bỏ phiếu trắng (abstain) chuyển giao sự kiện lên Tầng 2 khi đặc trưng bị bóp méo vượt 30%. Các phán quyết ánh xạ theo chính sách 4 dải tự tin (0,85 / 0,65 / 0,40 cho BLOCK_IP / ESCALATE / ALERT / LOG), bảo đảm lệnh tự động chặn chỉ thi hành khi đạt độ tự tin cao nhất và có đồng thuận từ bộ lọc chữ ký.

3.4 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đe dọa

Tầng 2 vận hành mô hình an ninh Foundation-Sec-8B-Instruct [20] (GGUF Q4_K_M) phục vụ bởi engine llama.cpp biên dịch CUDA trên GPU cục bộ. Quy trình suy luận được điều phối bởi đồ thị LangGraph [22] qua 5 trạm xử lý: kiểm tra rào chắn (guardrails), bồi đắp ngữ cảnh (rag_context), phân loại sự cố (llm_triage), ánh xạ kỹ thuật (attack_mapper), và thi hành phán quyết (action_executor) hoặc chuyển duyệt thủ công (human_in_the_loop). Sơ đồ trạng thái tác tử thể hiện tại Hình 3.

Tại attack_mapper, nếu thiếu chứng cứ tri thức, sự cố tự động chuyển sang hàng đợi chuyên viên (AWAIT_HITL) thay vì phỏng đoán. Tại llm_triage, nhãn phân loại nội bộ được gỡ khỏi prompt để bảo đảm tính khách quan. Ngữ cảnh được tối ưu bằng thuật toán nén nhật ký Drain [34] kết hợp giám sát ngân sách token.

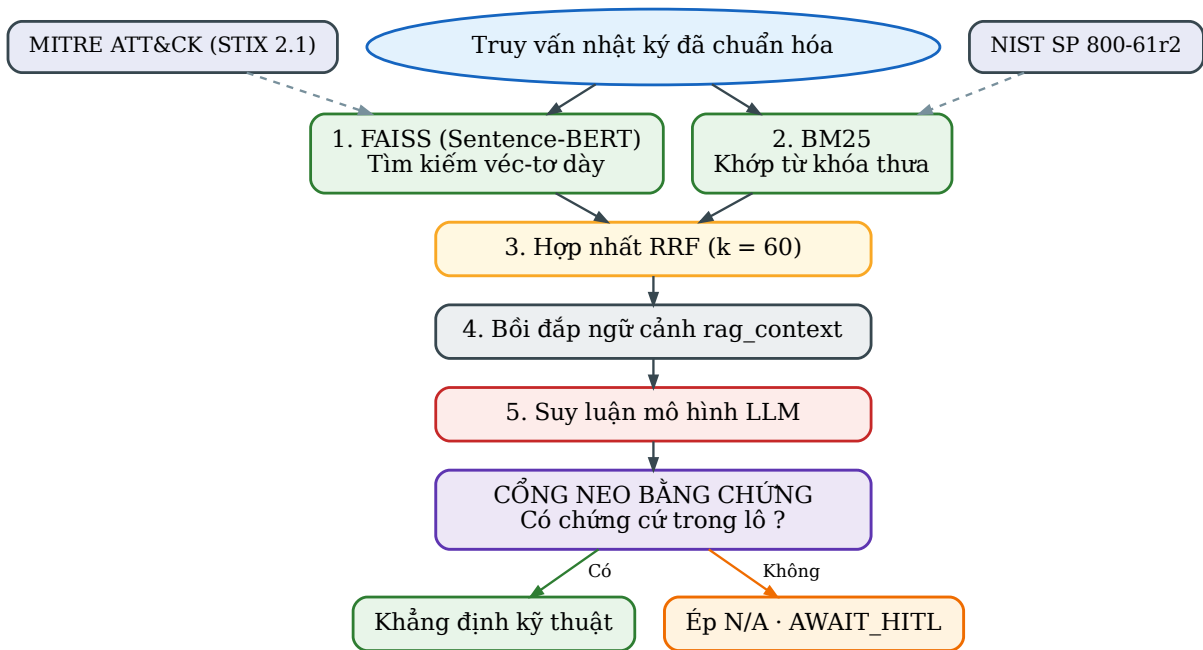
Để liên kết hành vi tấn công đa giai đoạn, Tầng 2 duy trì Bộ nhớ Đe dọa trên SQLite (chế độ rollback-journal tránh xung đột khóa Docker). Điểm uy tín S suy giảm theo thời gian im lặng t : $S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t$ với λ là hệ số suy giảm. Khi $S = 100$, Tầng 1 áp dụng cơ chế chặn-ngay-khi-thấy (block-on-sight) vĩnh viễn mà không cần tái kích hoạt Tầng 2. Các thực thể hạ tầng nội bộ được bảo vệ bằng danh sách trắng (whitelist) nhằm triệt tiêu rủi ro tự gây từ chối dịch vụ (Self-DoS).



Hình 3. Đồ thị trạng thái tác tử Tầng 2. (Nguồn: Tác giả)

3.5 Cơ chế Truy xuất Tri thức Lai Dual-RAG

Để triệt tiêu ảo giác, Tầng 2 truy xuất trên cơ sở tri thức gồm 433 mục MITRE ATT&CK (STIX 2.1) [35] và NIST SP 800-61r2 [36]. Đường ống song song kết hợp FAISS [24] (Sentence-BERT [37]) tìm véc-tơ dày theo ý đồ và BM25 [25] khớp từ khóa thừa cho mã CVE, cổng dịch vụ. Kết quả hợp nhất thứ hạng qua Reciprocal Rank Fusion (RRF, $k = 60$) [26] nạp vào nút rag_context (Hình 4).



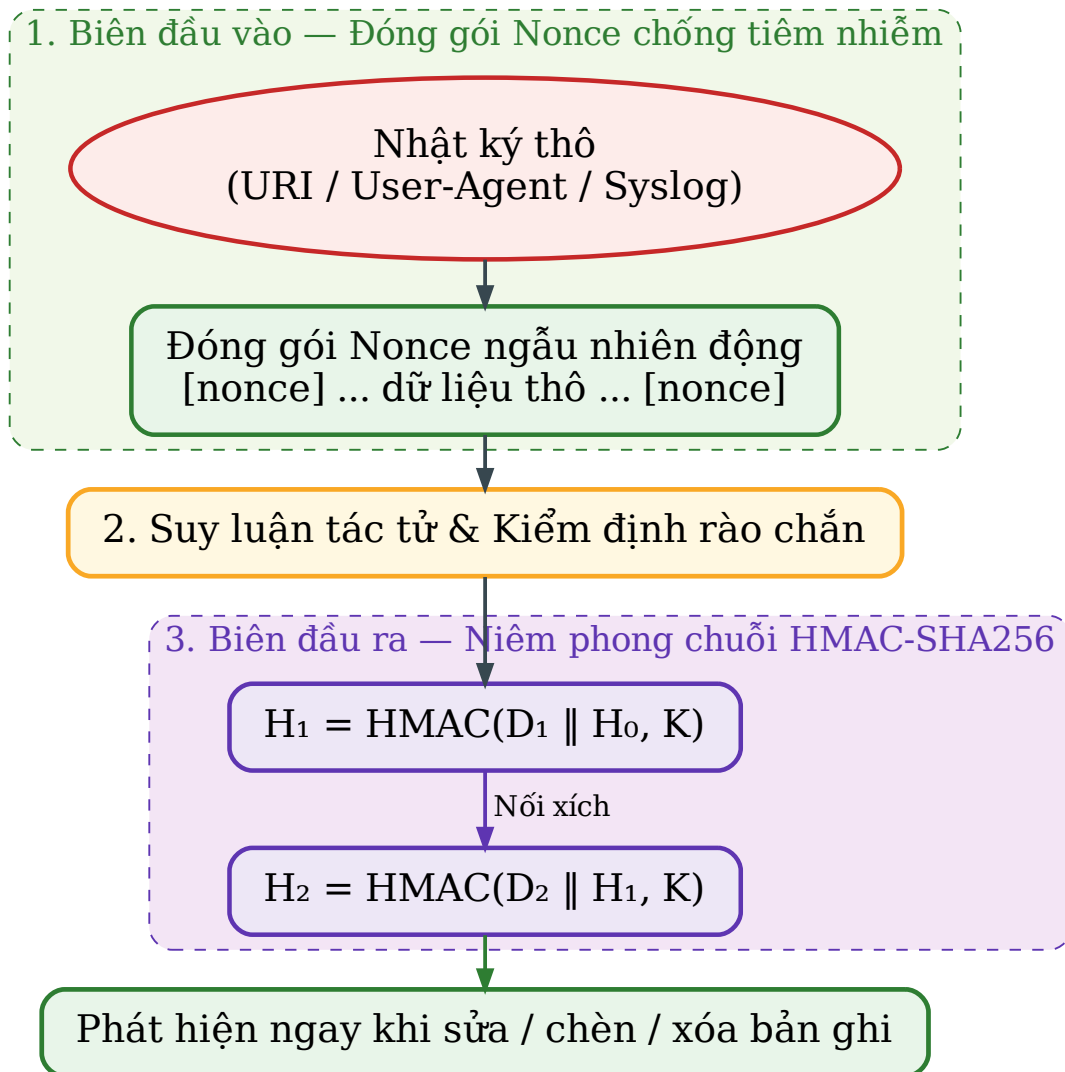
Hình 4. Sơ đồ truy xuất Dual-RAG và rào chắn neo bằng chứng đầu ra. (Nguồn: Tác giả)

Văn bản truy xuất được bộ khử độc RAG chuẩn hóa Unicode, loại bỏ thẻ HTML/Markdown và mệnh lệnh nhằm chặn tiềm nhiệm gián tiếp. Ở đầu ra, rào chắn neo bằng chứng đối chiếu ngược mã MITRE ATT&CK của mô hình với tài liệu trong lô. Nếu không xuất hiện trong chứng cứ, mã bị ép về N/A và chuyển sang hàng đợi AWAIT_HITL, triệt tiêu hoàn toàn rủi ro hư cấu kỹ thuật.

3.6 Kiến trúc An ninh AI và Niêm phong Kiểm toán Mật mã

Tấn công tiêm nhiễm câu lệnh qua nhật ký (Log Prompt Injection) [6, 8] nhúng chỉ thị điều khiển vào các trường nhật ký thô (User-Agent, URI). SENTINEL giải quyết bằng cơ chế Đóng gói Dữ liệu Phân định (Delimited Data Encapsulation) dùng chuỗi Nonce ngẫu nhiên sinh mới theo lô, ngăn chặn tấn công chèn ký tự thoát vùng bọc (Hình 5). Ba bộ thẩm định tất định bảo vệ ranh giới: Dữ liệu (loại nhật ký dị dạng), Quyết định (ép lược đồ Pydantic LLMDecision, từ chối chặn IP nội bộ), và Phản hồi (Zero Trust cho luật AI).

Về kiểm toán pháp y, mỗi bản ghi phán quyết D_i được liên kết chuỗi mật mã bằng HMAC-



Hình 5. Cơ chế đóng gói Nonce đầu vào và chuỗi niêm phong HMAC đầu ra. (Nguồn: Tác giả)

SHA256 [28]:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.1)$$

với H_{i-1} là hash liền trước và K là khóa bí mật cục bộ. Hành vi chỉnh sửa, chèn hoặc xóa bản ghi sẽ làm phá vỡ tính liên tục chuỗi và bị phát hiện ngay lập tức, đảm bảo khả năng chống giả mạo bằng chứng.

Chương 4

Thực nghiệm và Đánh giá

Chương này trình bày toàn bộ kết quả đánh giá thực nghiệm định lượng hệ thống SENTINEL trên 3 khía cạnh: hiệu năng xả tải lưu lượng, năng lực bảo vệ an ninh đối kháng AI kèm niềm phong kiểm toán mật mã, và chất lượng suy luận nhận thức tác tử. Hệ thống được đánh giá trên máy chủ cách ly mạng (Docker Compose, Intel Core i7, 32 GB RAM, GPU NVIDIA cục bộ chạy CUDA 11.6.2 với Foundation-Sec-8B-Instruct [20]). Theo phương pháp luận tại Mục 3.1, tỷ lệ xả tải được đo trực tiếp trên các luồng lưu lượng thực tế (Benchmark 25.649 sự kiện và SOC-like 99.717 sự kiện), trong khi chất lượng phân loại và rào chắn được đánh giá trên các tập dữ liệu chuẩn hóa (CSE-CIC-IDS2018 [10], CSIC 2010 [11], DAPT 2020 [12]) cùng 823 mẫu đối kháng (AdvBench [13], deepset [14], jackhhao [15], Shen và cộng sự [38]). Trong suốt quá trình đo đạc, các luật động được đóng băng và 50 mẫu do tác giả biên soạn trong `ground_truth.json` được loại trừ hoàn toàn khỏi mọi tính toán tỷ lệ. Tất cả các thước đo thực nghiệm đều công khai mẫu số đo đạc tương ứng nhằm bảo đảm tính minh bạch và khả năng tái lập.

4.1 Hiệu năng Xả tải Lưu lượng và Kinh tế học Tầng lọc

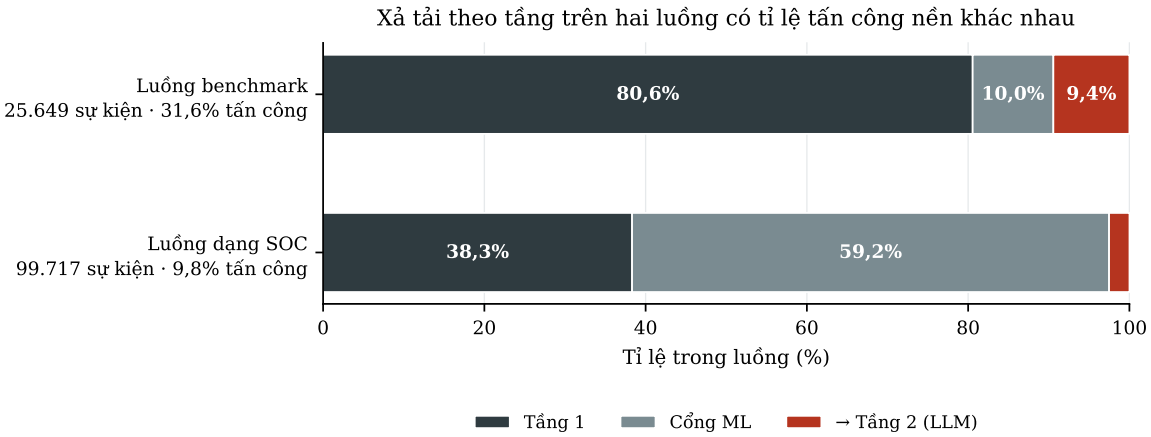
Một sự kiện được tính là đã gỡ tải thành công khi nó không phát sinh lời gọi mô hình ngôn ngữ nào (Mục 3.2); việc chỉ đếm hành động DROP sẽ bỏ sót các phán quyết BLOCK_IP, ALERT và AWAIT_HITL, vốn cũng không tiêu tốn tài nguyên token.

Bảng 2 mang chính đóng góp: tỉ lệ gỡ tải là hàm của tỉ lệ tấn công nên trong luồng, không phải hằng số của hệ. Trong cùng một luồng, nó phân tách tuyến tính thành gỡ tải(p) = $(1 - p) \cdot \text{gỡ tải}_{\text{lạnh}} + p \cdot \text{gỡ tải}_{\text{tấn công}}$. Hai hệ số theo nhãn của luồng chuẩn, 92,35% với ca

Bảng 2. Tỷ lệ Xả tải theo Từng Tầng trên Hai Luồng có Base-rate Khác nhau

Tầng giải quyết	Luồng benchmark 25.649 sk		Luồng dạng SOC 99.717 sk	
	Số sự kiện	Tỷ lệ	Số sự kiện	Tỷ lệ
Tầng 1 (luật + Welford + chữ ký)	20.663	80,6%	38.207	38,3%
Cổng Học máy (LightGBM 4 dải)	2.568	10,0%	58.992	59,2%
Cộng dồn (không chậm LLM)	23.231	90,6%	97.199	97,5%
Còn lại → Tầng 2 (LLM)	2.418	9,4%	2.518	2,5%
Tỷ lệ tấn công của luồng	31,6%		9,8%	

lành và 86,72% với ca tấn công, tái lập đúng con số đo được 90,6%; trên luồng dạng SOC, 97,88% và 93,77% tái lập 97,5%. Vì các hệ số khác nhau giữa hai luồng, quan hệ này cho phép ngoại suy sang một tỷ lệ nền khác trong cùng một luồng chứ không cho phép bê từ luồng này sang luồng kia—và 90,6% vì thế không phải cái trần mà là hệ quả của một luồng thử nạp tỷ lệ tấn công cao hơn ba lần mức thực tế. Tầng gánh chính cũng đảo vai: Tầng 1 giải quyết 80,6% ở luồng benchmark, còn Cổng ML mới là tầng gánh chính với 59,2% ở luồng lành áp đảo, tức hai tầng bù trừ cho nhau chứ không chồng lấn.



Hình 6. Cơ cấu xả tải trên hai luồng; tầng gánh chính đảo vai theo tỷ lệ tấn công nền. Sinh từ `offload_vs_baserate_{stream,demo}.json`. (Nguồn: Tác giả)

Cổng Học máy xử lý một véc-tơ đặc trưng trong 0,287 ms (3.452 sự kiện/giây) và bộ đệm Tầng 1.75 trúng 81,3% trong 1.500 truy vấn với mức tăng tốc 8,9×. Một con số chất lượng phải nằm cạnh những số trên, vì tỷ lệ gỡ tải 90,6% cũng đọc xuôi tai y như cho qua gần hết nếu phần đã gỡ tải bị phán quyết sai: trên `datatest.json`, Cổng đạt MCC 0,667 và Balanced Accuracy 0,833—dùng MCC thay Accuracy, bởi trả lời lành ở mọi nơi đã đạt

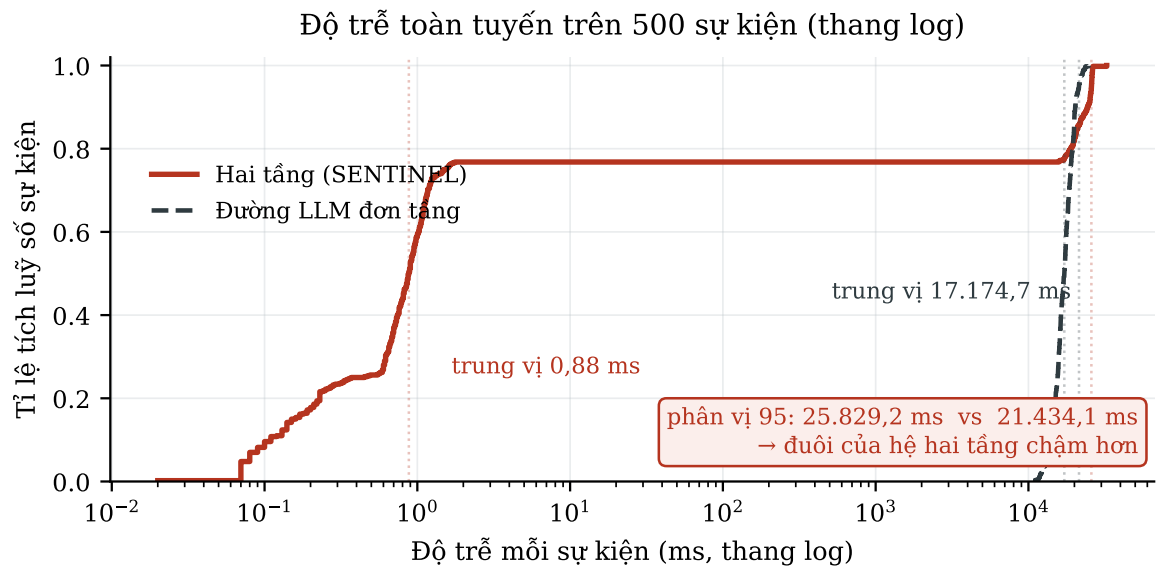
90,2% Accuracy trên luồng dạng SOC. Mẫu số đi kèm: trong 4.236 sự kiện, Cổng chỉ phán quyết 2.534, vì 1.586 sự kiện thiếu đặc trưng payload và 116 ca bỏ phiếu trắng. Phần 962 lệnh tự động chặn đạt Precision 100% với không một dương tính giả, và đó là điều kiện bắt buộc chứ không phải thành tích: gỡ tải mà chặn nhầm khách hàng thật là tổn thất, không phải hiệu quả.

Thu 598 luật từ các phán quyết chặn của Cổng làm tỉ lệ leo thang giảm từ 20,28% xuống 17,98%, tức giảm tương đối 11,35%, trong khi chất lượng phát hiện tăng chứ không giảm. Hai giới hạn giữ cho tuyên bố đúng tầm: giá trị MCC tuyệt đối vẫn thấp ($0,071 \rightarrow 0,109$), nên thực nghiệm chứng minh cơ chế vận hành được chứ không chứng minh Tầng 1 mạnh; và mô phỏng lạc quan, vì kẻ tấn công không đổi địa chỉ nguồn còn chuyên viên duyệt mọi luật đề xuất.

Trên 500 sự kiện lấy mẫu bước nhảy từ `build_stream()`, độ trễ trung bình giảm từ 17.187,9 ms xuống 5.286,7 ms ($-69,2\%$, kiểm định Mann-Whitney U $p \approx 9 \times 10^{-57}$), còn trung vị từ 17.174,7 ms xuống 0,88 ms—khoảng 19.500 lần, bởi sự kiện điển hình không bao giờ chạm tới mô hình. Hai kết quả bất lợi phải nêu. Phân vị thứ 95 xấu hơn, 25.829 ms so với 21.434 ms, và xấu vì cấu trúc: một sự kiện có leo thang thì đã trả chi phí Tầng 1 và Cổng trước khi trả chi phí mô hình, nên lợi ích nằm ở trung vị chứ không ở phần đuôi. Và tỉ lệ gỡ tải của chính lượt đo này chỉ đạt 76,8%, không phải 90,6% như Bảng 2, vì 500 mẫu lấy theo bước nhảy không tích lũy đủ tiền sử theo địa chỉ để danh sách chặn phát huy tác dụng. Phần tài nguyên báo bằng số lời gọi đã tránh (97.199 trên 99.717 sự kiện) chứ không bằng tỉ lệ giảm VRAM, bởi không có phép đo VRAM nào được thực hiện.

Bốn cấu hình đối chứng được đo trên cùng một mẫu con 150 sự kiện phân tầng, thay vì chép số headline từ công trình khác—phép so đó bắc qua hai tập dữ liệu và hai định nghĩa chỉ số khác nhau.

Đường tắt định chạy nhanh hơn $20.531 \times$ so với đẩy mọi sự kiện lên mô hình. Chữ ký tĩnh còn nhanh hơn nữa, khoảng ba lần SENTINEL, đúng như dự kiến vì chúng không thực hiện phép suy luận nào. Chính thứ tự này là luận điểm kiến trúc gói trong một dòng: mỗi tầng tồn đúng phần chi phí của nó, và câu hỏi thiết kế là giải quyết được bao nhiêu lưu lượng



Hình 7. Phân phối tích lũy độ trễ trên cùng 500 sự kiện. Lợi thế tập trung ở thân phân phối; ở phần đuôi thì hệ hai tầng chậm hơn. Sinh từ latency_benchmark.json. (Nguồn: Tác giả)

Bảng 3. Thông lượng các cấu hình đối chứng trên cùng mẫu con 150 sự kiện phân tầng

Cấu hình đối chứng	Thông lượng
H1: Chữ ký tĩnh (30 họ WAF)	11.129 sk/s
SENTINEL: Tầng 1 + Cổng ML	3.860 sk/s
H2: LightGBM đơn tầng, ngưỡng phẳng	2.162 sk/s
H3: LLM đơn tầng (cùng dữ liệu, mô hình và prompt)	0,19 sk/s

trước khi chạm tầng đất. Hai con số trong bảng không được cộng gộp, vì mức 0,19 sk/s đưa mỗi sự kiện qua toàn bộ tác tử Tầng 2 còn mốc 17.187,9 ms là một lời gọi mô hình trần, không trần token. Khi thử tải dồn trên luồng 99.717 sự kiện, backpressure theo độ trễ consumer-group giữ RAM và VRAM ổn định.

Ngưỡng chặn nằm trên một vùng phẳng—0,70 tới 0,85 cho chất lượng tổng hợp trùng khít, chỉ từ 0,90 trở lên độ bao phủ mới tụt—nên chọn 0,85 mua được biên an toàn rộng nhất cho việc tự động chặn mà không mất gì đo được, và độ chính xác của phần tự chặn giữ 1,00 trên mọi cấu hình đã quét. Với các bất thường tổng hợp tiêm từ 2σ tới 100σ trên bảy đặc trưng luồng, mọi phép thử ở mọi biên độ đều được leo thang nên không có gì lọt qua trong im lặng; nhưng phần nhận biết thống kê thì chứng lại, tăng từ 19,52% ở 2σ lên 42,86% ở 4σ rồi chỉ đạt 54,29% ở 100σ . Vượt quá khoảng bốn độ lệch chuẩn, giới hạn nằm ở tập đặc trưng chứ không ở ngưỡng, nên hành vi mới lạ tới được Tầng 2 nhờ leo thang chứ không nhờ nhận dạng—kiểu thất bại đúng đắn, nhưng không phải một tuyên bố về năng lực phát hiện.

4.2 Rào chắn Đối kháng AI và Tính toàn vẹn Kiểm toán Mật mã

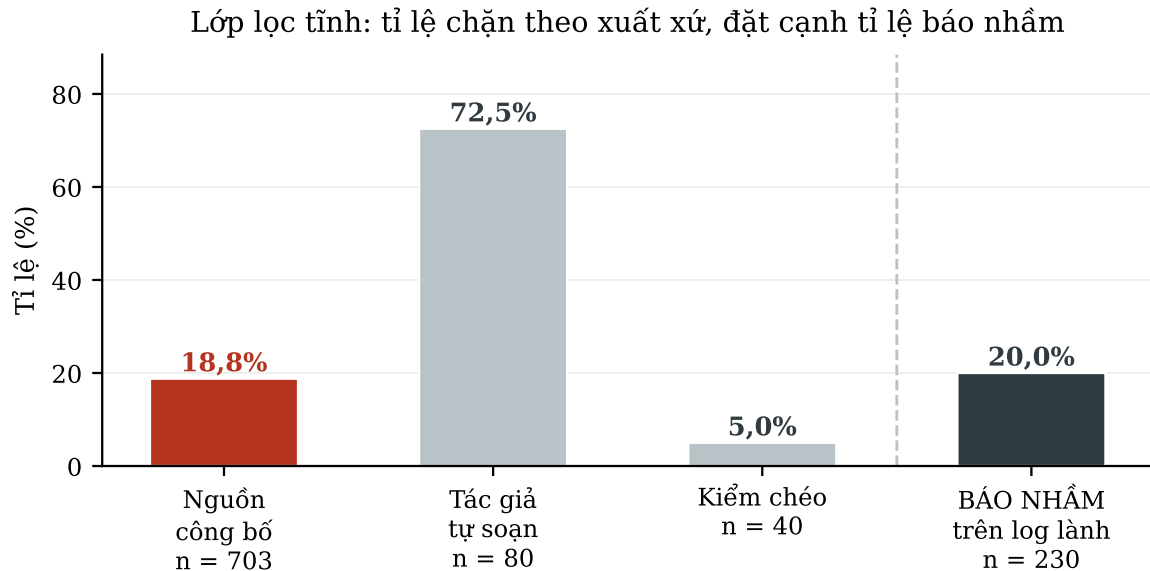
RQ2 nêu tiêm nhiễm qua nền nhật ký là rủi ro *diễn hình* chứ không phải toàn bộ phạm vi, nên hai mặt tấn công khác hẳn nhau về cấu trúc đều được đánh giá: tấn công qua ngôn ngữ, nơi kháng được nghĩa là chỉ thị nhúng không làm đổi hành động của tác tử, và tấn công qua không gian đặc trưng, nơi kháng được nghĩa là mẫu bị bóp méo vẫn không bị lật thành lành. Ba giao ước làm cho các tỉ lệ đọc được. Phán quyết của lớp tính là phép HOẶC của ba bộ dò ghi nhận riêng, để khi hỏng thì định vị được. Đối chứng âm trên 230 nhật ký lành là bắt buộc, bởi một lớp gấn cờ mọi thứ cũng đạt chặn 100%. Và mẫu từ nguồn công bố không bao giờ gộp với mẫu do tác giả biên soạn.

Lớp lọc tính chặn được 18,8% các nguồn công bố, và con số đó phải đọc kèm tỉ lệ báo nhầm 20,0% trên nhật ký lành. Cả 46 lần báo nhầm đều xuất phát từ lớp phát hiện mã hoá, và cái giá của chúng có giới hạn: một cờ tính chỉ nâng mức cô lập và chú thích bản ghi, chứ không loại sự kiện hay chặn nguồn, nên đó là tỉ lệ chú thích thừa chứ không phải tỉ lệ lưu

Bảng 4. Các lớp rào chắn, mẫu số phép đo và kết quả

Lớp rào chắn	Mẫu số	Kết quả
<i>Tầng 1: Tấn công qua ngôn ngữ</i>		
Lớp lọc tĩnh, nguồn công bố	703 mẫu	132 → 18,8%
theo bộ dò: khớp mẫu / mã hoá / phân định	703	114 / 29 / 0
Lớp lọc tĩnh, mẫu tác giả biên soạn	80 mẫu	58 → 72,5%
Lớp lọc tĩnh, tập kiểm chéo	40 mẫu	2 → 5,0%
Lớp lọc tĩnh: báo nhầm trên nhật ký lành	230 nhật ký lành	46 → 20,0%
trong đó: lớp nhận dạng mã hoá	46/46	toàn bộ
<i>Tầng 1: Tấn công qua không gian đặc trưng</i>		
Cổng ML: né tránh, chế độ khó (bóp méo mọi đặc trưng; 13 ca bị lật, CI95 97,86–99,27)	1.036 ca tấn công đã bắt	1.023 → 98,75%
Cổng ML: chế độ một đặc trưng (∞ / cực đoan)	1.036×2	100% cả hai
Cổng ML: từ chối phán quyết khi đầu vào biến dạng	4.236 sự kiện	116 → leo thang
<i>Tầng 2: Bảo chứng cấu trúc</i>		
Đóng gói dữ liệu phân định bằng nonce	678 mẫu khó, độ phủ 100%	678 → 100%
Tập theo vị trí trường, tách từng vị trí	100 mẫu công bố	24/24, 23/23, 30/30, 23/23
Kiểm lược đồ khi ép hồng cổ máy suy luận	1 lần ép hồng	AWAIT_HITL, không sụp
Tất định (cùng hạt giống, 5 lượt) / đổi riêng hạt giống	5 lượt / 10 mẫu	trùng khớp / 0 ca lật
Chống tràn ngữ cảnh	cửa sổ 16.384 token, ngân sách 4.000	xấu nhất 1.655
<i>Toàn vẹn pháp y</i>		
HMAC: ba kiểu giả mạo cốt lõi	30 lượt mỗi kiểu	100%
HMAC: đối chứng âm (chuỗi nguyên vẹn)	450 bản ghi	không báo động giả
HMAC: cắt đuôi chuỗi	N/A	0% (không phát hiện)

lượng lành bị từ chối phục vụ. Tập tự soạn bị chặn ở mức 72,5% vì 45 trong 80 mẫu ấy là ca né tránh bằng mã hoá mà bộ vô hiệu hoá sinh ra đúng để trị; báo con số gộp 23,3% sẽ tăng bóc hệ thống bằng cách đếm cả những mẫu viết ra khi đã biết cơ chế phòng thủ, nên 18,8% mới là con số luận văn đứng sau.



Hình 8. Lớp lọc tĩnh: tỉ lệ chặn theo xuất xứ đặt cạnh tỉ lệ báo nhầm trên log lành. Sinh từ `robustness_results.json` và `adversarial_negative_results.json`. (Nguồn: Tác giả)

Ở chế độ khó, nơi *toàn bộ* đặc trưng của một ca tấn công đã bị bắt đúng bị đẩy tới cực trị, 98,75% số mẫu vẫn kháng được. Hai chế độ một-đặc-trung đạt 100%, và luận văn trích chế độ khó chứ không trích trung bình ba chế độ, vì gộp thêm hai chế độ bảo hoà tầm thường sẽ thổi con số vượt quá mức phòng tuyến thực sự chứng minh được. Việc từ chối phán quyết được tính là kết quả của rào chắn: 116 sự kiện được đẩy lên thay vì đoán bừa.

Bảo chứng an ninh đến từ Đóng gói Dữ liệu Phân định, đánh giá ở độ phủ 100% trên toàn bộ 678 mẫu thuộc bảy nhóm mà lớp tĩnh không hấp thụ được—tập cha của 543 mẫu thật sự lọt qua, nên phép thử chặt hơn mức cần thiết chứ không phải được lấy mẫu thiên vị. Tầng 2 kháng được 678 trên 678. Đó là khác biệt về bản chất: một bộ phân loại chặn $x\%$ thì luôn để lọt phần còn lại và suy giảm trước biến thể mới, còn một bảo chứng cấu trúc thì hoàn toàn không phụ thuộc vào việc nhận dạng nội dung độc hại, nên con số 18,8% không mâu thuẫn với luận văn mà định lượng khỏi việc lớp cấu trúc phải gánh. Vị trí trường được đo tách riêng, vì cơ chế bóc theo từng trường và không con số gộp nào kiểm được: trên 100

mẫu rải qua URI, User-Agent, message và payload, lớp tính chặn 12 còn Tầng 2 kháng cả 100, đồng đều ở cả bốn vị trí. Hai phép kiểm ổn định chống đỡ cho các phép đo phụ thuộc mô hình, mỗi phép kèm giới hạn: hạt giống cố định cho hành động trùng khớp qua năm lượt nhưng chỉ trên một mẫu, còn đổi riêng hạt giống trên mười mẫu không làm lật phán quyết nào—ở $n = 10$ điều đó chỉ chặn tỉ lệ lật ở mức 0,2775 và bảo hoà trên một hành động duy nhất.

Việc kiểm chứng tính lại toàn bộ chuỗi từ bản ghi khởi thuỷ; vì mỗi mắt xích tiêu thụ hash của mắt xích trước, một byte bị sửa trong D_j làm hỏng mọi mắt xích từ j trở đi, nên phát hiện có định vị chứ không chỉ là báo rằng có gì đó đã đổi. Ba kiểu giả mạo cốt lõi—sửa nội dung, chèn bản ghi giả, xoá bản ghi giữa chuỗi—đều bị phát hiện trong 30 trên 30 lượt thử, và đối chứng âm trên 450 bản ghi nguyên vẹn không sinh báo động giả nào. Phép đo chạy với khoá nạp từ môi trường chứ không phải khoá mặc định trong mã, bởi một khoá lộ trong mã nguồn cho phép giả mạo lại cả chuỗi và làm vô hiệu mọi tỉ lệ ở trên. Cắt đuôi chuỗi thì không phát hiện được—thuộc tính cố hữu của kỹ thuật nối chuỗi nhật ký—và cách khắc phục là neo định kỳ giá trị băm ra ngoài hệ thống.

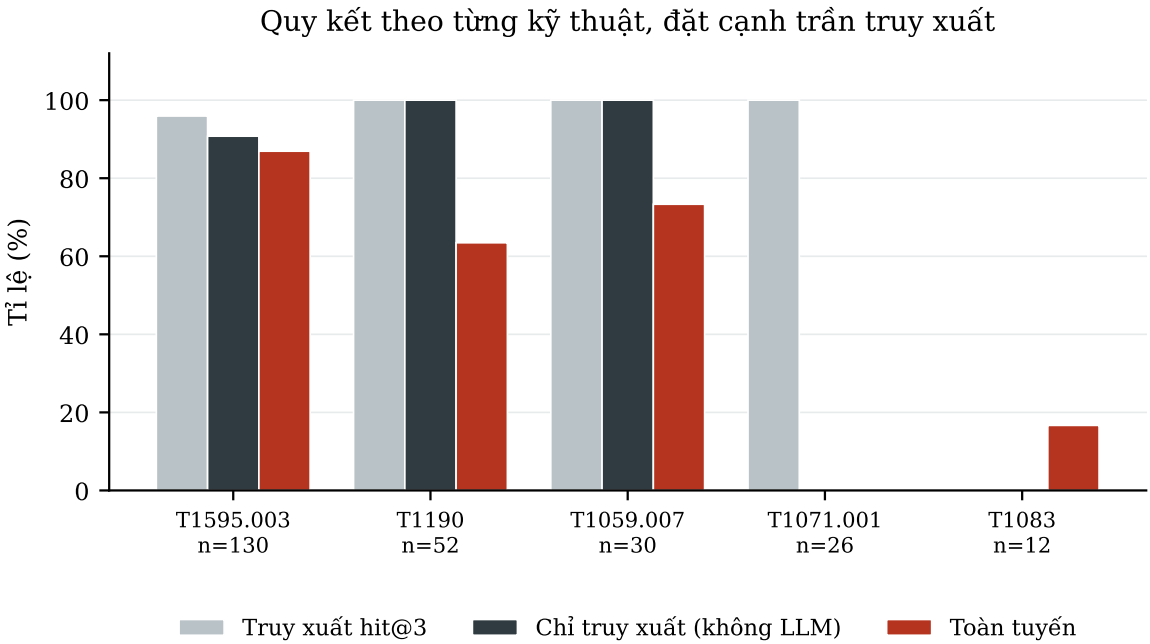
Một phép đo đã phải chạy lại, và lý do thì khái quát được. Kết quả theo từng vị trí ban đầu chỉ dựa trên 79 phán quyết độc lập chứ không phải 100, vì khoá cache lớp hai bỏ sót `user_agent` và gộp 23 mẫu User-Agent về hai dấu vân: hai phán quyết phát lại hai mươi một lần, đúng ở cột mà thí nghiệm sinh ra để kiểm. Một khiếm khuyết của dụng cụ đo và một mặt tấn công đầu độc cache đang sống ở đây là cùng một khiếm khuyết, bởi kẻ tấn công trong vận hành cũng có thể đổi riêng một trường vắng mặt trong khoá và nhận lại phán quyết đã lưu. Mở rộng khoá đưa số dấu vân về đúng 100; kết quả sau khi sửa trùng khít con số trước khi sửa, và đó chính là lý do mẫu số phải được kiểm chứ không được mặc định là đúng.

4.3 Suy luận Nhận thức Tác tử và Quy kết Kỹ thuật Tấn công

Bốn khía cạnh của RQ3 (quy kết kỹ thuật, hiệu năng truy xuất, báo cáo minh bạch và giảm tải chuyên viên) được đánh giá độc lập.

Bảng 5. Quy kết theo từng kỹ thuật trên lát 500 mẫu tăng payload, kèm trần truy xuất của cùng bộ truy vấn.

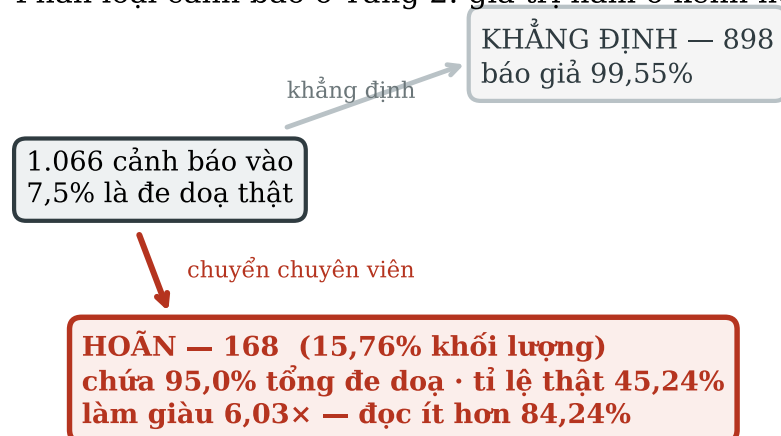
Kỹ thuật ATT&CK	<i>n</i>	Truy xuất hit@3	Chỉ truy xuất	Toàn tuyến
T1190: Khai thác ứng dụng công khai	52	1,00	100,0%	63,5%
T1059.007: Thực thi JavaScript	30	1,00	100,0%	73,3%
T1595.003: Quét theo từ điển	130	0,96	90,8%	86,9%
T1083: Dò tệp và thư mục	12	0,00	0,0%	16,7%
T1071.001: Giao thức web	26	1,00	0,0%	0,0%
Toàn bộ kỹ thuật	250	0,93	80,0%	68,0%



Hình 9. Quy kết theo từng kỹ thuật đặt cạnh trần truy xuất. Chỗ nào cột nhạt cao mà hai cột đậm bằng không thì lỗi ở bộ ánh xạ; chỗ nào cột nhạt bằng không thì lỗi ở kho tri thức. Sinh từ ba tệp kết quả RQ3. (Nguồn: Tác giả)

Trên cùng lát 243 truy vấn đã leo thang, Dual-RAG đạt $\text{Recall@3} = 0,930$ (KTC 95% 0,891–0,956) và MRR 0,803, nằm phía trên các con số quy kết nên mạch lập luận khép kín: truy xuất không phải thành phần gây sụt giảm hiệu năng.

Phân loại cảnh báo ở Tầng 2: giá trị nằm ở kênh hoãn, không ở phán quyết



Hình 10. Phân loại cảnh báo ở Tầng 2. Kênh khẳng định gần như toàn báo giả; kênh hoãn mới là nơi đe dọa thật dồn về. Sinh từ `tier2_decision_results.json`. (Nguồn: Tác giả)

Một trọng tài khác họ mô hình (Meta-Llama-3-8B-Instruct chấm Foundation-Sec-8B-Instruct) chấm toàn bộ 1.052 sự kiện leo thang trên bốn trục RAGAS [39], theo đúng khuyến nghị nhằm loại bỏ Thiên kiến Tự đề cao [40]: độ chính xác ngữ cảnh 2,54; độ liên quan câu trả lời 4,52; độ trung thành 3,96; độ bao phủ ngữ cảnh 4,11; trung bình 3,78/5,0. Hai kết quả bất lợi cho hệ. Độ chính xác ngữ cảnh 2,54 là trục yếu nhất và củng cố chẩn đoán về truy xuất, vì tập tài liệu trả về thường mang theo những mục không liên quan tới sự kiện đang xét. Nghiêm trọng hơn, chỉ số neo bằng chứng chỉ đạt 11,2% (KTC 95% 9,5–13,3): khoảng chín trên mười lời biện giải không dẫn ra một giá trị log nào đối chiếu ngược lại bản ghi được. Đây là khoảng cách rõ nét nhất giữa cái kiến trúc *bảo chứng* và cái nó *tự nguyện đưa ra*—rào chắn neo chứng minh được mã đã khẳng định có tài liệu đỡ lưng, nhưng không có gì buộc phần văn xuôi xung quanh phải trích những giá trị trường đã dẫn tới đó—nên về báo cáo pháp y minh bạch mới đạt một phần, và bịt nó là việc ràng buộc định dạng biện giải chứ không phải cải thiện mô hình.

Ở phép bóc tách thành phần, cách chấm nhị phân không dùng được: tỉ lệ tấn công 86,9% khiến mọi cấu hình cho điểm sát con số đó và phép so sập đổ, đó là lý do trước đây mọi cấu hình trông y hệt nhau. Chấm theo hành động cuối—phán quyết phát ra có khớp phán quyết

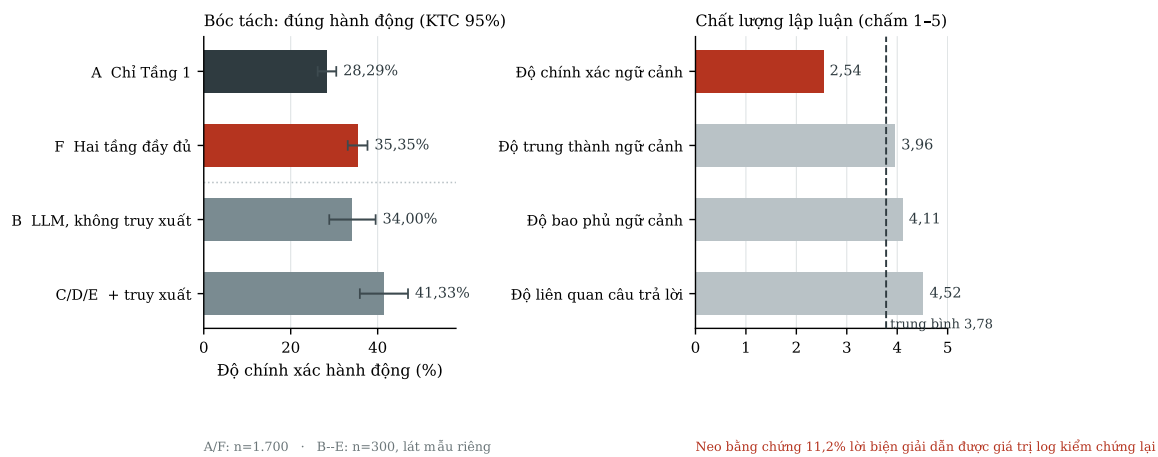
kỳ vọng hay không, trên bốn giá trị BLOCK_IP, ALERT, LOG và AWAIT_HITL—khôi phục lại khả năng phân biệt. Việc đổi thuốc được nêu ra thay vì lặng lẽ bỏ qua, vì một thuốc chọn sau khi đã thấy kết quả là thuốc đáng ngờ; căn cứ ở đây là thuốc nhị phân suy biến trên phân bố này, không phải vì nó cho con số khó coi.

Bảng 6. Bóc tách thành phần chấm theo hành động cuối, đã loại 50 mẫu tác giả tự soạn. Cấu hình A và F chấm trên toàn bộ 1.700 mẫu còn lại; B–E chấm trên một lát 300 mẫu riêng nên không so trực tiếp với A và F được. Sinh từ `ablation_action_scores.json`.

Cấu hình	<i>n</i>	Đúng h.động (KTC 95%)	Tự quyết	Hoãn	C.xác tự quyết
A — Chỉ Tầng 1, không LLM	1.700	28,29% (26,20–30,48)	41,00%	0,00%	69,01%
F — Hệ hai tầng đầy đủ	1.700	35,35% (33,12–37,66)	55,24%	44,76%	57,72%
B — LLM, không truy xuất	300	34,00% (28,87–39,53)	69,67%	30,33%	45,93%
C — + truy xuất dày	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%
D — + truy xuất thưa	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%
E — + hợp nhất hạng	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%

Ba phát hiện rút ra, và cái thứ hai đáng kể nhất. Tầng suy luận xứng đáng với chi phí của nó, 35,35% so với 28,29%, hai khoảng tin cậy không chồng lấn. Nhưng sự đánh đổi đảo chiều: riêng Tầng 1 lại là bên phán quyết đáng tin hơn mỗi khi nó chịu quyết, 69,01% so với 57,72%, mà nó chỉ chịu quyết trên 41,00% số sự kiện và bỏ ngỏ 59,00%, đẩy chúng lên một tầng mà ở cấu hình A vốn không tồn tại. Hệ đầy đủ không bỏ ngỏ ca nào, chuyển toàn bộ phần tồn đọng thành 44,76% ca hoãn tường minh. Hai tầng khác nhau không nhiều ở chỗ suy nghĩ giỏi đến đâu, mà ở cách hành xử khi không biết—đúng thuộc tính mà kênh hoãn đã đo từ chiều ngược lại. Thứ ba, một kết quả rỗng: C, D và E trùng khít tới từng chữ số, nên thêm truy xuất thưa vào truy xuất dày rồi hợp nhất hai bảng hạng không làm đổi một phán quyết nào trên lát này. Đó là giới hạn của thiết kế bóc tách chứ không phải bằng chứng rằng bậc thang truy xuất vô dụng, vì cả ba cấu hình chỉ gọi mô hình với sự kiện đã leo thang còn phần còn lại rơi về cùng một `tier1_verdict`. Muốn cô lập đóng góp của phép hợp nhất hạng thì phải đánh giá riêng trên các sự kiện đã leo thang—đúng thứ phép đo truy xuất ở trên cung cấp còn phép bóc tách này thì không.

Khả năng tương quan có trạng thái dựng lại được cả 3/3 chuỗi đa ngày thật của DAPT2020 mà không sinh cảnh báo chiến dịch giả nào trên 4 chuỗi lành, nhưng ba ca dương đặt khoảng tin cậy 95% của độ bao phủ vào giữa 0,44 và 1,00, tương thích với cả một hệ chạy



Hình 11. Trái: độ chính xác hành động theo cấu hình kèm khoảng tin cậy 95%; A và F chung mẫu số, B–E thì không. Phải: bốn trục trọng tài chấm, với độ chính xác ngữ cảnh là trục yếu. Sinh từ `ablation_action_scores.json` và `reasoning_eval_results.json`. (Nguồn: Tác giả)

đúng lẫn một hệ gặp may, nên tương quan đa giai đoạn vẫn ở mức minh chứng khả thi. Cuối cùng, một kết quả tưởng như tiêu cực lại xác nhận thiết kế: trên nhóm mẫu ngoài NetFlow, Cổng ML chỉ đạt Recall 11,1% và 305 trong 336 ca trượt của toàn tập nằm gọn trong nhóm này, bởi Cổng học trên đặc trưng luồng còn tấn công web nằm ở payload—phần việc của Tầng 2 và tập chữ ký. Recall tổng 0,755 vì thế đang trộn hai quần thể không cộng được và phải báo tách bạch. Liên quan tới điều đó, như đã nêu ở Mục 3.4, tỉ lệ chuyển chuyên gia không phải chỉ số cần tối thiểu hoá: một kiến trúc tuyên bố tỉ lệ chuyển-người bằng 0 trên mọi tình huống là kiến trúc đã bỏ mất rào chắn cuối cùng.

Chương 5

Kết luận

Một Trung tâm Điều hành An ninh hiểm khi thất bại vì một cuộc xâm nhập không bị phát hiện. Nó thất bại ở bước sau phát hiện, nơi một số hữu hạn chuyên viên phải quyết định trong dòng cảnh báo gần như vô hạn thì cái nào đáng được chú ý. Mô hình ngôn ngữ là công nghệ đầu tiên đọc được một sự kiện trong ngữ cảnh của nó và diễn giải bằng thứ ngôn ngữ con người hành động được, nhưng đặt nó vào luồng vận hành lại phát sinh những khoản chi phí về thời gian, về niềm tin và về chủ quyền dữ liệu mà không con số độ chính xác đầu bảng nào giải quyết. Luận văn đặt câu hỏi liệu có thể có được năng lực ấy mà không phải trả đủ cái giá của nó, và trả lời bằng cách xây dựng SENTINEL—một kiến trúc hai tầng giải quyết phán quyết rẽ trước phán quyết dứt, triển khai hoàn toàn trên một máy trạm cục bộ—rồi đo nó thay vì mô tả nó. Ba kết quả đồ lấy tuyên bố đó.

Kinh tế học phân tầng đứng vững như một quy luật hệ thống. Tầng 1 (kết hợp bộ luật chữ ký tầng ứng dụng Rule-based và bộ lọc thống kê Welford) cùng Cổng Học máy LightGBM giải quyết 90,6% một luồng chuẩn mang tỉ lệ tấn công cao hơn ba lần mức thực tế, và 97,5% một luồng ở tỉ lệ nền gần thực tế, cả hai đều không tốn một lời gọi mô hình ngôn ngữ nào. Vì sự kiện điển hình không bao giờ chạm tới mô hình, độ trễ toàn tuyến ở mức trung vị giảm còn 0,88 ms so với 17.174,7 ms của đường đơn tầng. Kết quả phương pháp luận cho thấy tỷ lệ gỡ tải phân tách tuyến tính thành tỷ lệ trên ca lạnh và tỷ lệ trên ca tấn công, tức là một hàm phụ thuộc trực tiếp vào tỷ lệ tấn công nền của luồng lưu lượng chứ không phải hằng số cố định của hệ thống.

Bảo chứng an ninh mang tính cấu trúc, nên không suy giảm theo thời gian. Đóng gói Dữ liệu Phân định xử lý nội dung nằm trong ranh giới nonce theo lô như văn bản thụ động bất kể nội dung đó nói gì, và kháng được toàn bộ 678 mẫu đối kháng thuộc những nhóm mà

lớp lọc tĩnh rẻ tiền không hấp thụ nổi—đúng những nhóm mà lớp lọc ấy mù hoàn toàn. Đây là một loại bảo đảm khác hẳn với một bộ phân loại chặn được $x\%$ rồi để lọt phần còn lại trước mọi cách diễn đạt mới. Chuỗi HMAC-SHA256 phát hiện 100% cả ba kiểu giả mạo cốt lõi mà không báo động giả lần nào trên chuỗi đối chứng nguyên vẹn, niêm phong hồ sơ pháp y bằng tính toán vẹn và khả năng phát hiện giả mạo.

Kiểm soát hư cấu trở thành một ràng buộc kiểm chứng được thay vì một kỳ vọng. Mọi mã ATT&CK hệ phát ra đều phải hiện diện trong tài liệu truy xuất của chính lô đó; trên 1.421 phán quyết có khẳng định kỹ thuật, không một trường hợp nào thiếu neo. Số không ấy không phải điểm số tầm thường của một lá chắn không bao giờ ra tay: nó can thiệp trên 9,26% số lô, và 76 lần can thiệp trong đó đã giữ lại một lệnh chặn IP vĩnh viễn mà hệ thống không biện giải nổi bằng chứng cứ. Tầng suy luận cũng tỏ ra hữu ích nhất ở một vai trò khác với vai trò hiển nhiên—dùng làm bộ định tuyến phân loại thay vì bộ tự khẳng định, hàng đợi hoãn của nó gom 95,0% đe dọa thật vào 15,76% khối lượng, tức làm giàu $6,03\times$ và cắt đi 84,24% lượng tài liệu chuyên viên phải đọc.

Các giới hạn của kiến trúc được báo cáo đầy đủ ở nơi có bằng chứng của chúng, tại Chương 4, và ba trong số đó định ra chương trình làm việc trước mắt: quy kết hiện tốt hơn khi không có tầng suy luận, tác tử chưa tự bác bỏ được một cảnh báo giả, và tầng giải thích là mắt xích yếu nhất, bởi truy xuất còn để lọt tài liệu không liên quan và chỉ 11,2% lời biện giải dẫn ra một giá trị log đối chiếu ngược được với bản ghi. Các hướng tương ứng là sửa tầng truy xuất từ gốc kho tri thức, hiệu chuẩn tác tử cho cả việc bác bỏ chứ không chỉ việc khẳng định, và một định dạng biện giải buộc phải trích dẫn thay vì chỉ cho phép trích dẫn. Hai mở rộng nhỏ hơn suy ra từ những tính chất đã nêu: neo định kỳ giá trị băm ra ngoài hệ thống sẽ bịt điểm mù cắt đuôi vốn có của chuỗi nhật ký, và chữ ký bất đối xứng sẽ nâng khả năng phát hiện giả mạo lên thành chống chối bỏ thực sự.

Khép lại một nỗ lực nghiên cứu nghiêm túc, nhưng mở ra những khát vọng sâu xa trong hành trình bảo vệ không gian số bằng sức mạnh của Trí tuệ Nhân tạo Tác tử.

Tài liệu tham khảo

- [1] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [2] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [3] B. A. AlAhmadi, L. Axon, and I. Martinovic, “99% False Positives: A Qualitative Study of SOC Analysts’ Perspectives on Security Alarms,” in *Proceedings of the 31st USENIX Security Symposium*, 2022, pp. 2783–2800.
- [4] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [5] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [6] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [7] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [8] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [9] OWASP Foundation, “OWASP Top 10:2021 - The Ten Most Critical Web Application Security Risks,” The OWASP Foundation, 2021. [Online]. Available: <https://owasp.org/Top10/>
- [10] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [11] C. Torrano-Giménez, A. Pérez-Villegas, and G. Álvarez Maraón, “HTTP DATASET CSIC 2010,” Information Security Institute, Spanish National Research Council (CSIC), 2010. [Online]. Available: <https://www.isi.csic.es/dataset/HTTP>
- [12] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [13] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and Transferable Adversarial Attacks on Aligned Language Models,” *arXiv preprint arXiv:2307.15043*, 2023.

- [14] Deepset, “Prompt Injections Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/deepset/prompt-injections>
- [15] jackhhao, “Jailbreak Classification Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/jackhhao/jailbreak-classification>
- [16] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [17] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [18] G. Ke, Q. Meng, T. Finley, T. Wang, W. Chen, W. Ma, Q. Ye, and T. Y. Liu, “LightGBM: A Highly Efficient Gradient Boosting Decision Tree,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 3146–3154, 2017.
- [19] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [20] S. Weerawardhena, P. Kassianik, B. Nelson, B. Saglam *et al.* (Cisco Foundation AI), “Llama-3.1-FoundationAI-SecurityLLM-8B-Instruct Technical Report,” *arXiv preprint arXiv:2508.01059*, 2025.
- [21] P. Kassianik, B. Saglam *et al.* (Cisco Foundation AI), “Llama-3.1-FoundationAI-SecurityLLM-Base-8B Technical Report,” *arXiv preprint arXiv:2504.21039*, 2025.
- [22] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [23] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [24] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.
- [25] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–389, 2009.
- [26] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Rank Learning Methods,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
- [27] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [28] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [29] J. Zhang *et al.*, “When LLMs Meet Cybersecurity: A Systematic Literature Review,” *Cybersecurity*, vol. 8, 2025.
- [30] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [31] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation,” *arXiv preprint arXiv:2508.13118*, 2025.
- [32] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [33] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with

- Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [34] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
 - [35] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.
 - [36] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
 - [37] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
 - [38] X. Shen, Z. Chen, M. Backes, Y. Shen, and Y. Zhang, “‘Do Anything Now’: Characterizing and Evaluating In-The-Wild Jailbreak Prompts on Large Language Models,” in *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2024, pp. 1671–1685.
 - [39] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
 - [40] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.
 - [41] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, “A Design Science Research Methodology for Information Systems Research,” *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, 2007.